DEPARTMENT OF COMPUTER & INFORMATION SYSTEMS ENGINEERING
BACHELORS IN COMPUTER SYSTEMS ENGINEERING
Course Code: CS-326
Course Title: Software Engineering
Complex Engineering Activity
TE Batch 2024, Fall Semester 2026
Course Instructor: Dr. Fakhra Aftab

Problem Statement:

Prepare a Software Requirements Specification (SRS) to ensure that all system requirements are accurately identified, clearly documented, and verifiable, providing a reliable foundation for design, development, and testing activities.

Course Learning Outcome:

(CLO-2) "**Explore** communication tools for a software development team."

Complex problem-solving attributes (CPA) covered (as per PEC - OBA manual – 2019):

- **CPA-1 Range of Resources:** Involve the use of diverse resources (and for this purpose, resources include people, money, equipment, materials, information and technologies).
- **CPA-2 Level of interaction:** Require resolution of significant problems arising from interactions between wide ranging or conflicting technical, engineering or other issues.
- **CPA-3 Familiarity:** Can extend beyond previous experiences by applying principles-based approaches.

Objective:

To develop a comprehensive Software Requirements Specification (SRS) document for the selected software engineering project, encompassing all functional, non-functional, and domain-specific requirements. The requirements shall be clearly defined using appropriate specification techniques, quantifiable, and aligned with the established acceptance criteria.

- Define the system's scope and identify potential stakeholders, categorizing them according to distinct viewpoints. (CPA-1, CPA-2)
- Describe all user functional requirements using clear and precise natural language statements. (CPA-1, CPA-2)
- Transform the identified user requirements into detailed system-level functional requirements. (CPA-2, CPA-3)
- Develop the interaction and behavioral models representing the system's operational environment and dynamics. (CPA-3)
- Specify the required database tables essential for system functionality. (CPA-1, CPA-2, CPA-3)
- Prepare and finalize the complete document using the LaTeX typesetting tool. (CPA-1, CPA-2, CPA-3)

Deliverables:

Software Requirement Specification (SRS) Document.

DEPARTMENT OF COMPUTER & INFORMATION SYSTEMS ENGINEERING
BACHELORS IN COMPUTER SYSTEMS ENGINEERING

Course Code: CS-326
Course Title: Software Engineering
Complex Engineering Problem
TE Batch 2024, Fall Semester 2026
Grading Rubric

TERM PROJECT

Roll#	**Roll#**	**Roll#**	**Roll#**

Project Title: _____

Criteria	**Excellent (5)**	**Good (4 or 3)**	**Satisfactory (2)**	**NI (1 or 0)**
1. Scope and Stakeholder Identification	Scope and stakeholders are comprehensively defined and categorized with full clarity.	Minor details missing in scope or stakeholder categorization.	Scope or stakeholder list lacks completeness or clarity.	Scope is vague, and stakeholder identification is missing or incorrect.
2. User Functional Requirements	All user requirements are well-structured, precise, and traceable.	Most requirements are clear; minor ambiguity exists.	Requirements are partially clear; some are incomplete.	Requirements are unclear or missing key user functions.
3. System Functional Requirements	Comprehensive, detailed, and consistent with user requirements.	Adequate detail and traceability; minor inconsistencies.	Limited detail; partial linkage to user requirements.	Poorly defined or inconsistent with user requirements.
4. Interaction and Behavioral Models	Models are clear, accurate, and well-labeled; fully aligned with requirements.	Models are understandable with minor missing details.	Models are partially correct but lack clarity or consistency.	Models are missing, unclear, or incorrect.
5. Database Design	Tables and relationships are complete, logically designed, and consistent with requirements.	Tables mostly accurate; minor inconsistencies.	Tables incomplete or weakly connected to system functions.	Database design missing or incorrect.
6. Document Quality and Presentation (LaTeX)	Professionally formatted, free of errors, logically structured, and visually consistent.	Well-structured with minor formatting issues.	Acceptable but lacks consistency or contains minor errors.	Poorly formatted, incomplete, or unclear.

Total Score (out of 30): _____

Teacher's Signature: _____

SOFTWARE REQUIREMENT SPECIFICATION (SRS)

SENTRA-X

AN EVIDENCE-GROUNDED AND UNCERTAINTY-AWARE HUMAN-IN-THE-LOOP SOC ALERT TRIAGE COPILOT

VERSION 1.4

Asad Ullah Zafar (CS-24082)

Atta Ur Rehman (CS-24092)

Abdur Rehman (CS-24098)

Department of Computer and Information Systems Engineering
NED University of Engineering & Technology

Submitted to

Sir Ali Akhtar (Practical Class Teacher)
Dr. Fakhra Aftab (Theory Class Teacher)

October 14, 2026

Document Attribute	Details
Document Version	1.4
Release Date	October 14, 2026
Institution	Department of Computer and Information Systems Engineering, NED University of Engineering & Technology
Authors	Asad Ullah Zafar (CS-24082), Atta Ur Rehman (CS-24092), Abdur Rehman (CS-24098)
Supervisors / **Reviewers**	Sir Ali Akhtar (Practical Class Teacher), Dr. Fakhra Aftab (Theory Class Teacher)

Contents

1 Introduction **5**
- 1.1 Purpose . . . 5
- 1.2 Scope . . . 5
- 1.3 Definitions, Acronyms, and Abbreviations . . . 6
- 1.4 References . . . 7
- 1.5 Document Overview . . . 7

2 Overall Description **8**
- 2.1 Product Perspective . . . 8
- 2.2 Product Functions . . . 8
- 2.3 User Characteristics . . . 8
- 2.4 Constraints Summary . . . 9
- 2.5 Assumptions and Dependencies Summary . . . 9
- 2.6 Stakeholder Identification and Viewpoint Categorization . . . 9
- 2.7 User Functional Requirements . . . 10
- 2.8 User-to-System Requirements Transformation Matrix . . . 12

3 System Features / Functional Requirements **14**
- 3.1 FR-1: Alert Ingestion & Noise Filtering . . . 14
- 3.2 FR-2: Evidence-Grounded AI Triage & Prompt-Injection Sanitization . . . 15
- 3.3 FR-3: Deterministic Safety Floor & Abstention Rules Engine . . . 17
- 3.4 FR-4: Dynamic Few-Shot Feedback Calibration . . . 18
- 3.5 FR-5: Prioritized Analyst Review Queue & Evidence Trace Modal . . . 19
- 3.6 FR-6: Analyst & Team Lead Decision Capture . . . 20
- 3.7 FR-7: Agreement & Guardrail Analytics Reporting . . . 21
- 3.8 FR-8: User Authentication & Role-Based Access Control (RBAC) . . . 22
- 3.9 FR-9: Host & Asset Criticality Registry . . . 23
- 3.10 FR-10: Adversarial & Baseline Evaluation Runner . . . 24

4 External Interface Requirements **26**
- 4.1 User Interfaces . . . 26
- 4.2 Hardware Interfaces . . . 26
- 4.3 Software Interfaces . . . 26
- 4.4 Communication Protocols . . . 27

5 Non-Functional Requirements **28**
- 5.1 Performance Requirements (NFR-1) . . . 28
- 5.2 Reliability & Availability Requirements (NFR-2) . . . 28
- 5.3 Security & Adversarial Robustness Requirements (NFR-3) . . . 29

5.4 Usability Requirements 29
5.5 Scalability Requirements (NFR-5) 29
5.6 Maintainability & Portability Requirements (NFR-6) 29
5.7 Domain-Specific Requirements 29

6 System Models **31**
6.1 System Context Model 32
6.2 Use Case Model 32
6.3 Data Flow Model (DFD Level 1) 33
6.4 Alert Lifecycle State Model 34
6.5 Interaction Model (Sequence Diagrams) 34
6.6 Behavioral Model (Guardrail Decision Activity Flow) 37
6.7 Use Case Specifications 38

7 Data Requirements **40**
7.1 Logical Data Model (Entity-Relationship Diagram) 40
7.2 Relational Database Schema & Data Dictionary 40
7.2.1 Column-Level Data Dictionary 41
7.3 Data Flow, Indexing, Integrity & Retention 43

8 Constraints **44**
8.1 Technical Constraints 44
8.2 Business & Operational Constraints 44
8.3 Regulatory, Safety & Security Constraints 44

9 Assumptions & Dependencies **45**
9.1 Operational Assumptions 45
9.2 External & Technical Dependencies 45

10 Appendices **46**
10.1 Appendix A: Requirements Traceability Matrix (RTM) 46
10.2 Appendix B: Adversarial Prompt-Injection Evaluation Benchmark 46
10.3 Appendix C: Document Revision History 47
10.4 Appendix D: Acceptance Criteria 47

Chapter 1

Introduction

1.1 Purpose

This Software Requirements Specification (SRS) defines the functional, non-functional, interface, system modeling, and data requirements for **Sentra-X**, an evidence-grounded, uncertainty-aware, human-in-the-loop alert triage copilot for Security Operations Centers (SOCs). This document serves as the authoritative specification for project supervisors, academic evaluators, and the development team, following IEEE Std 830-1998 best practices while remaining scoped to a 5th-semester Software Engineering deliverable.

1.2 Scope

Security Operations Centers face chronic alert fatigue from high-volume SIEM/XDR platforms such as **Wazuh**. Analysts must manually inspect raw JSON logs to determine whether an alert represents a genuine threat (True Positive) or benign activity (False Positive)—a slow, repetitive process prone to human oversight. Conversely, naive Large Language Model (LLM) triage tools suffer from hallucinated threat attributions, overconfident binary classifications on incomplete evidence, silent downgrading of critical detections, and vulnerability to indirect prompt injection embedded in untrusted log fields.

Sentra-X operates between Wazuh and the security analyst as a guarded decision-support copilot: 1. **Alert Ingestion:** Pulls qualifying alerts from Wazuh via REST API polling or webhook push while filtering out low-level informational noise. 2. **Evidence Pack Compilation:** Enriches each alert with Wazuh rule metadata, MITRE ATT&CK technique mappings, target host criticality, and temporally correlated historical alerts from the same host or source IP. 3. **Prompt-Injection Defense:** Sanitizes and structurally isolates untrusted log strings inside read-only JSON data envelopes before LLM invocation. 4. **Evidence-Grounded AI Triage:** Queries a hosted LLM (Google Gemini or Anthropic Claude) under strict JSON schema constraints, requiring explicit **dot-notation cited evidence keys** from the Evidence Pack. 5. **Deterministic Guardrails:** Enforces **Abstention Rules** (routing low-confidence, ungrounded, or

contradictory assessments to `NEEDS_ANALYST_REVIEW`) and a multi-tier **Safety Floor** (blocking AI downgrades or false-positive dismissals on High/Critical Wazuh alerts). 6. **Dynamic Few-Shot Feedback Calibration:** Stores verified human override rationales and dynamically injects the top 2 matching exemplars into future prompts without retraining model weights. 7. **Human-in-the-Loop Dashboard:** Presents prioritized queues, visual evidence traces, one-click decision capture, and Team Lead agreement/calibration analytics via a React.js single-page application.

Out-of-Scope Boundaries: Sentra-X is strictly a **read-only decision-support system**. It never modifies Wazuh rules or agent configurations, never executes autonomous active-response or containment actions (e.g., blocking IPs, killing processes, or modifying firewall rules), and does not perform LLM weight fine-tuning. Final disposition authority always remains with the human analyst.

1.3 Definitions, Acronyms, and Abbreviations

Term / Acronym	Definition
SOC	Security Operations Center.
SIEM	Security Information and Event Management.
XDR	Extended Detection and Response.
TP / FP	True Positive (genuine threat) / False Positive (benign activity triggering a rule).
LLM	Large Language Model (Google Gemini or Anthropic Claude).
IoC	Indicator of Compromise (e.g., malicious IP, file hash, domain, or command pattern).
MITRE ATT&CK	Globally accessible knowledge base of adversary tactics and techniques.
RBAC	Role-Based Access Control (`Analyst`, `TeamLead`, `Admin`).
JWT	JSON Web Token used for stateless API authentication.
Evidence Pack	A structured JSON object combining raw alert telemetry, MITRE ATT&CK metadata, host criticality tier, and correlated historical alerts for the same host or source IP.
Abstention	The deliberate refusal of the triage engine to force a binary TP/FP verdict when evidence is incomplete, low-confidence, or ungrounded, routing the alert to `NEEDS_ANALYST_REVIEW`.
Safety Floor	A deterministic backend policy preventing High/Critical Wazuh rules (levels ≥ 10) from being downgraded or dismissed as False Positives by AI inference.
Feedback Calibration	Dynamically retrieving verified human override rationales from PostgreSQL as few-shot in-context exemplars to calibrate future prompts without model fine-tuning.
Alert Fatigue	Desensitization and cognitive overload of SOC analysts caused by high volumes of repetitive or false-positive SIEM alerts.

Term / Acronym	Definition
Dot-Notation Citation Key	A hierarchical JSON path (e.g., `telemetry_payload.data.win.eventdata.commandLine`) returned in `cited_evidence_keys` and verified against the Evidence Pack.
Few-Shot Exemplar	A prior human override record (rule, process signature, asset criticality, verdict, severity, rationale) injected into the LLM prompt as in-context guidance.
Feedback Poisoning	A failure mode where a mistaken analyst override biases future prompts into misclassifying genuine attacks as False Positives; mitigated by tiered matching and revocation (`FR-4`) and the safety floor (`FR-3`).
Indirect Prompt Injection	An attack in which instructions are embedded in log telemetry (e.g., a command line or User-Agent) to hijack the triage output.
Process Signature	Normalized identifier of the originating executable, script path, or decoder extracted from a Wazuh alert, used for exemplar matching.

1.4 References

1. Asad Ullah Zafar, Atta Ur Rehman, and Abdur Rehman, *Sentra-X Software Engineering Project Proposal*, Department of CIS Engineering, NED University of Engineering & Technology, September 2026.
2. IEEE Computer Society, *IEEE Std 830-1998: IEEE Recommended Practice for Software Requirements Specifications*, 1998.
3. Wazuh Inc., *Wazuh v4.x REST API & Alert Format Documentation*, `https://documentation.wazuh.com`.

1.5 Document Overview

- **Section 2:** product perspective, user classes, stakeholders by viewpoint, user requirements (`UR-1` to `UR-27`), and their transformation into system requirements.
- **Section 3:** the ten functional requirements (`FR-1` to `FR-10`).
- **Section 4:** user, hardware, software, and communication interfaces.
- **Section 5:** measurable non-functional requirements and domain-specific requirements (§5.7).
- **Section 6:** system, use case, data flow, state, interaction, and behavioral models, and use case specifications.
- **Section 7:** logical ER model, relational schema with column-level data dictionary, indexing, and retention.
- **Sections 8 & 9:** constraints, assumptions, and dependencies.
- **Section 10:** requirements traceability matrix, adversarial benchmark specification, revision history, and acceptance criteria.

Chapter 2

Overall Description

2.1 Product Perspective

Sentra-X is a self-contained, containerized web application that integrates with an existing Wazuh SIEM/XDR deployment via a read-only REST API or webhook listener. It operates alongside Wazuh without altering SIEM detection rules or endpoint agents. All ingested alerts, Evidence Packs, AI assessments, asset criticality records, and immutable analyst decisions are stored in Sentra-X's dedicated PostgreSQL database.

The system consists of three runtime containers: the Sentra-X Core Backend (Python / FastAPI), the relational database (PostgreSQL 16), and the Analyst & Team Lead Dashboard (React.js single-page application).

2.2 Product Functions

Sentra-X provides the ten functions specified in Chapter 3 (`FR-1` to `FR-10`): alert ingestion and noise filtering, evidence-grounded LLM triage with prompt-injection sanitization, deterministic abstention and safety-floor rules, few-shot feedback calibration, a prioritized review queue with evidence trace, decision capture with an audit trail, agreement analytics, role-based access control, host criticality management, and adversarial benchmarking.

2.3 User Characteristics

User Class	System Role	Technical Proficiency & Domain Background	Core Responsibilities
SOC Analyst	`Analyst`	Understands security alerts, log fields, and basic MITRE ATT&CK concepts; no programming expertise required.	Reviews `AWAITING_ANALYST` and `NEEDS_MANUAL_TRIAGE` queues, inspects cited evidence, and submits `Approve`, `Override` (with rationale), `Manual Triage`, or `Escalate` decisions.

User Class	System Role	Technical Proficiency & Domain Background	Core Responsibilities
SOC Team Lead	`TeamLead`	Senior responder experienced in incident escalation, SIEM rule tuning, and analyst quality assurance.	Resolves `ESCALATED` alerts, monitors AI-analyst agreement and calibration trends, exports audit CSVs, assigns host criticality tiers, and revokes faulty override exemplars.
System Administrator	`Admin`	Proficient in Linux, Docker Compose, networking, REST APIs, and credential management.	Manages Wazuh API connectivity, LLM provider keys, ingestion thresholds, user accounts/roles, and runs benchmark evaluations (`FR-10`).

2.4 Constraints Summary

The principal constraints are read-only SIEM integration, a configuration-driven hosted-LLM adapter, no model weight fine-tuning, and a local data boundary for raw logs and audit trails (see Chapter 8).

2.5 Assumptions and Dependencies Summary

A reachable Wazuh Manager (or alert replay service) and API credentials for at least one hosted LLM provider are assumed (see Chapter 9).

2.6 Stakeholder Identification and Viewpoint Categorization

Stakeholders are the people, organizations, standards, and external systems that affect, or are affected by, Sentra-X. Each stakeholder is categorized by the **viewpoint** from which it contributes requirements:

- **Direct (Interactor) Viewpoint:** Stakeholders who operate Sentra-X through its dashboard or APIs.
- **External System Viewpoint:** Automated systems that exchange data with Sentra-X through defined interfaces.
- **Indirect (Organizational) Viewpoint:** Stakeholders who do not operate the system but depend on its outputs, governance, or accountability.
- **Domain & Regulatory Viewpoint:** Security-domain standards and data-handling rules that constrain how alerts are interpreted and stored.
- **Project & Academic Viewpoint:** Stakeholders who build, review, and evaluate the system.
- **Adversarial (Threat) Viewpoint:** Hostile parties whose behavior the system must withstand; their “requirements” are expressed as security constraints.

ID	Stakeholder	Viewpoint Category	Interest / Concerns	Influence on Requirements	Related Requirements
SH-1	SOC Analyst	Direct (Interactor)	Reduce alert fatigue, verify AI reasoning quickly, retain decision authority.	**High:** drives queue, evidence trace, and decision actions.	UR-1–UR-12, FR-5, FR-6
SH-2	SOC Team Lead	Direct (Interactor)	Resolve escalations, assure analyst/AI quality, calibrate feedback, manage asset criticality.	**High:** drives escalation, analytics, governance.	UR-13–UR-18, FR-4, FR-7, FR-9
SH-3	System Administrator	Direct (Interactor)	Deployment, configuration, user management, benchmark execution.	**Medium:** drives configuration, RBAC, and portability.	UR-19–UR-22, FR-1, FR-8, FR-10, NFR-2, NFR-6
SH-4	Wazuh SIEM / XDR	External System	Read-only alert source with defined JSON format and API limits.	**High:** defines input schema and ingestion rate.	FR-1, NFR-5, §4.3
SH-5	Hosted LLM API Providers (Google Gemini, Anthropic Claude)	External System	Availability, rate limits, structured-output support, request quotas.	**Medium:** drives timeout, retry, and adapter design.	FR-2, NFR-1, NFR-6
SH-6	SOC Manager / Security Leadership	Indirect (Organizational)	Operational efficiency, residual risk, accountability for AI-assisted decisions.	**Medium:** drives analytics and auditability.	UR-14, UR-25, FR-7, NFR-4
SH-7	Compliance & Audit Officers	Indirect (Organizational)	Immutable decision records, retention, data residency of raw telemetry.	**Medium:** drives audit, retention, and data-boundary constraints.	UR-25, FR-6, NFR-4, §8.3
SH-8	Asset Owners & Endpoint Users	Indirect (Organizational)	Critical hosts receive priority attention; monitoring must not disrupt endpoints.	**Low:** drives criticality tiers and the read-only constraint.	UR-17, UR-24, FR-9, §8.1
SH-9	Security Domain Standards (Wazuh rule-level scale, MITRE ATT&CK)	Domain & Regulatory	Consistent severity scale and technique taxonomy.	**Medium:** drives severity mapping and evidence enrichment.	DR-1, DR-2, FR-3
SH-10	Development Team (Authors)	Project & Academic	Feasibility within a single semester, maintainability, testability.	**High:** drives scope and constraints.	NFR-6
SH-11	Course Instructors / Evaluators (Sir Ali Akhtar, Dr. Fakhra Aftab)	Project & Academic	Completeness, verifiability, and traceability of requirements.	**High:** drives document structure and acceptance criteria.	Appendix A, Appendix D
SH-12	Adversarial Actors (log-injecting attackers, feedback poisoners)	Adversarial (Threat)	Embed instructions in log fields or induce faulty overrides to hide genuine attacks.	**Negative:** drives sanitization, safety floor, and exemplar revocation.	UR-27, FR-2, FR-3, FR-4, NFR-3

2.7 User Functional Requirements

The following requirements state, in natural language, what each user class needs from Sentra-X. They are technology-neutral and are refined into system-level functional requirements (FR-1 to FR-10) in Section 3 (see the transformation matrix in Section 2.8).

ID	Actor	User Requirement (Natural Language)	Priority
UR-1	SOC Analyst	The analyst shall be able to see a list of all alerts needing human attention, ordered so that the most severe and the oldest alerts appear first.	Essential
UR-2	SOC Analyst	The analyst shall be able to see, for every alert, the AI's verdict, recommended severity, confidence level, and a short plain-language explanation.	Essential

ID	Actor	User Requirement (Natural Language)	Priority
UR-3	SOC Analyst	The analyst shall be able to see exactly which pieces of log evidence the AI relied on, highlighted inside the alert details, without reading raw JSON.	Essential
UR-4	SOC Analyst	The analyst shall be clearly told when the AI declined to give a verdict, or when an AI attempt to downgrade or dismiss a serious alert was blocked, together with the reason.	Essential
UR-5	SOC Analyst	The analyst shall be able to filter and search the alert list by status, severity, rule, and free text.	Essential
UR-6	SOC Analyst	The analyst shall be able to see context for each alert: the host's criticality, the MITRE ATT&CK technique, and recent related alerts from the same host or source IP.	Essential
UR-7	SOC Analyst	The analyst shall be able to approve the AI's assessment with a single quick action.	Essential
UR-8	SOC Analyst	The analyst shall be able to override the AI's verdict or severity by providing a written justification.	Essential
UR-9	SOC Analyst	The analyst shall be able to escalate an alert to a Team Lead when unsure.	Essential
UR-10	SOC Analyst	When the AI could not assess an alert, the analyst shall be able to retry the AI or close the alert manually with a justification.	Essential
UR-11	SOC Analyst	The analyst shall not have to re-explain recurring benign patterns: verified past overrides shall automatically guide the AI on similar future alerts.	Essential
UR-12	SOC Analyst	The analyst shall not be shown informational noise or duplicate alerts.	Essential
UR-13	SOC Team Lead	The Team Lead shall be able to resolve escalated alerts by recording an authoritative severity, verdict, and justification.	Essential
UR-14	SOC Team Lead	The Team Lead shall be able to view agreement, override, escalation, and manual-triage rates, and guardrail activity, over a chosen period of up to 90 days.	Essential
UR-15	SOC Team Lead	The Team Lead shall be able to view the override-rate trend over time to judge whether feedback calibration is helping.	Essential
UR-16	SOC Team Lead	The Team Lead shall be able to export decisions for a single day or a date range as a CSV file for audit.	Essential
UR-17	SOC Team Lead	The Team Lead shall be able to view and update the criticality tier of monitored hosts.	Conditional
UR-18	SOC Team Lead	The Team Lead shall be able to review and revoke an incorrect feedback exemplar so that it no longer influences the AI.	Essential
UR-19	System Administrator	The administrator shall be able to configure the Wazuh connection, polling interval, and minimum alert level.	Essential
UR-20	System Administrator	The administrator shall be able to switch between the supported LLM providers by changing configuration only.	Essential
UR-21	System Administrator	The administrator shall be able to create and deactivate user accounts and assign each a role.	Essential

ID	Actor	User Requirement (Natural Language)	Priority
UR-22	System Administrator	The administrator shall be able to run a benchmark evaluation (including the 30-payload prompt-injection suite) comparing a raw LLM baseline against Sentra-X and receive a report.	Conditional
UR-23	All Users	Every user shall log in securely and shall only be able to use functions permitted to their role.	Essential
UR-24	All Users	The final disposition of every alert shall always be made by a human; the system shall never close an alert or take containment action on its own.	Essential
UR-25	Team Lead / Compliance	Every human decision shall be permanently recorded without possibility of alteration and retained for at least 12 months.	Essential
UR-26	All Users	A new qualifying alert shall have its AI assessment available to analysts within seconds (at most 8.0 seconds).	Essential
UR-27	All Users	Malicious content hidden inside log data shall never be able to instruct the AI into dismissing a genuine threat.	Essential

2.8 User-to-System Requirements Transformation Matrix

Each user requirement from Section 2.7 is transformed into one or more detailed system-level requirements in Section 3 (and non-functional requirements in Section 5). The final column states how the user need is made precise and verifiable.

User Req.	System-Level Requirement(s)	Related UC	Transformation (Refinement into System Behavior)
UR-1	FR-5	UC-3	Queue query returns AWAITING_ANALYST and NEEDS_MANUAL_TRIAGE alerts ordered by effective severity, then ingested_at ascending.
UR-2	FR-2, FR-5	UC-2, UC-3	Schema-constrained output (verdict, recommended_severity, confidence_score, explanation $\leq$ 500 chars) rendered as queue badges and modal summary.
UR-3	FR-2, FR-5	UC-3	cited_evidence_keys (dot-notation) validated against the Evidence Pack and highlighted in the split-pane modal.
UR-4	FR-3, FR-5	UC-2, UC-3	abstention_triggered / safety_floor_triggered flags with audit notes shown as queue indicators and a guardrail banner.
UR-5	FR-5	UC-3	Queue filter parameters status, severity, rule_id, search term, and page number.
UR-6	FR-2, FR-5, FR-9	UC-3	Evidence Pack asset_context, MITRE tags, and temporal_context ($K = 5$, 24h) displayed in the modal.
UR-7	FR-6, §5.4	UC-4	Approve transitions AWAITING_ANALYST $\rightarrow$ CLOSED with an audit row; reachable in at most 2 clicks.

User Req.	System-Level Requirement(s)	Related UC	Transformation (Refinement into System Behavior)
UR-8	FR-6, FR-4	UC-5	Override requires alternate verdict/severity and rationale $\geq$ 10 chars; creates an FR-4 exemplar.
UR-9	FR-6	UC-6	Escalate transitions the alert to ESCALATED with an audit row.
UR-10	FR-6, FR-2	UC-7	Retry AI Triage resets the retry count to PENDING_REVIEW; Manual Triage Closure requires severity, verdict, and rationale.
UR-11	FR-4, FR-2, FR-3	UC-2, UC-5	Tiered retrieval of up to 2 active exemplars injected into the prompt, always bounded by FR-3 safety floors.
UR-12	FR-1	UC-1	Rule-level filter (L_{min}) and idempotent deduplication on wazuh_alert_id.
UR-13	FR-6	UC-8	Resolve Escalation restricted to TeamLead; requires severity, verdict, and rationale; optionally creates an exemplar.
UR-14	FR-7	UC-9	Aggregate metrics over a date window $\leq$ 90 days, with optional rule_id filter.
UR-15	FR-7, FR-4	UC-9	Daily/weekly override-rate trendline rendered within $\leq$ 5 s for up to 50,000 alerts.
UR-16	FR-7	UC-9	Streaming CSV export of single-day or range decisions within $\leq$ 10 s.
UR-17	FR-9	UC-10	View/update tiers (LOW–CRITICAL); unseen agents auto-registered as MEDIUM; the modifying user and timestamp are recorded on the assets row.
UR-18	FR-4	UC-10	TeamLead sets is_active = false on an exemplar; it is immediately excluded from future prompts.
UR-19	FR-1	UC-11	Wazuh connection, polling interval N, and minimum level L_{min} are supplied as deployment configuration (environment variables); credentials are never stored in the database.
UR-20	FR-2, NFR-6	UC-11	Provider adapters (GeminiAdapter, ClaudeAdapter) selected by LLM_PROVIDER and API key only.
UR-21	FR-8 (User Account Administration)	UC-11	Admin-only create/deactivate/role-assign operations on the users table with bcrypt hashing.
UR-22	FR-10	UC-11	Benchmark replay in BASELINE_RAW_LLM and SENTRAX_FULL modes producing precision/recall/F1, abstention accuracy, and injection success rate.
UR-23	FR-8, NFR-3	UC-3–UC-11	Salted bcrypt login, signed JWT, per-endpoint role checks returning 401/403.
UR-24	FR-6, FR-3, §8.3	UC-4–UC-8	Only FR-6 transitions can set CLOSED; no containment/active-response code path exists.
UR-25	FR-6, NFR-4, §7.3	UC-4–UC-8	Append-only analyst_decisions_audit enforced by a database trigger; $\geq$ 12-month retention.
UR-26	NFR-1, FR-2, FR-3	UC-2	End-to-end latency $\leq$ 8.0 s from PENDING_REVIEW to AWAITING_ANALYST; 10 s LLM timeout with bounded retries.
UR-27	FR-2, FR-3, NFR-3	UC-2	PromptSanitizer, JSON envelope isolation, injection_suspect flag, and 0% bypass rate on 30 payloads.

Chapter 3

System Features / Functional Requirements

The system-level functional requirements below (FR-1 to FR-10) refine the natural-language user functional requirements (UR-1 to UR-27) defined in Section 2.7; the traceability from each UR to its FR is given in Section 2.8.

3.1 FR-1: Alert Ingestion & Noise Filtering

Attribute	Specification
Requirement ID	FR-1
Priority	Essential
Primary Actor	Wazuh SIEM / System Timer

- **Description:** Automatically pulls new security alerts from Wazuh via scheduled REST API polling or webhook push, filters out low-level informational events, deduplicates alerts, and queues qualifying records for AI triage.
- **Preconditions:**
  1. Sentra-X backend and PostgreSQL database containers are running and healthy.
  2. Wazuh API endpoint, credentials (or webhook secret), polling interval N (default 30 seconds), and minimum rule level threshold L_min (default 4) are configured.
- **Inputs:**
  - Raw Wazuh alert JSON objects containing id (unique alert ID), timestamp, rule (id, level, description, mitre), agent (id, name, ip), data (srcip, process/command fields), and full_log.
- **Processing:**
  1. Poll the Wazuh REST API every N seconds or authenticate incoming webhook POST payloads.

2. Inspect `rule.level` on each incoming alert. If `rule.level < L_min`, ignore/archive the event as informational noise without invoking the LLM.
3. Check the `alerts` table by `wazuh_alert_id`. If the ID already exists, skip insertion (idempotent deduplication).
4. Extract indexing metadata: `wazuh_alert_id`, `rule_id`, `rule_level`, `rule_description`, `agent_id`, `agent_name`, `src_ip`, and normalized `process_signature` (derived from `data.win.eventdata.image`, `syscheck.path`, or `decoder.name`).
5. If `agent_id` is not present in the `assets` table, auto-register the host with default `criticality_tier = MEDIUM` (`FR-9`).
6. Persist the alert record in `alerts` with `status = PENDING_REVIEW` and UTC `ingested_at` timestamp.

- **Outputs:**
  - Newly inserted row in `alerts` with `status = PENDING_REVIEW` and an enqueued triage job for `FR-2`.
- **Postconditions:**
  - Qualifying unseen alerts are durably stored in PostgreSQL and queued for Evidence Pack assembly.
- **Side Effects & Error Handling:**
  - Auto-creates a default `MEDIUM` asset entry in `assets` when a new `agent_id` is encountered.
  - If the Wazuh API is unreachable or returns an error, the backend logs a structured warning and retries on the next `N`-second cycle without terminating the service.

3.2 FR-2: Evidence-Grounded AI Triage & Prompt-Injection Sanitization

Attribute	Specification
Requirement ID	`FR-2`
Priority	Essential
Primary Actor	Backend Triage Orchestrator / Hosted LLM API

- **Description:** Assembles a structured Evidence Pack for each `PENDING_REVIEW` alert, sanitizes untrusted telemetry strings against indirect prompt injection, and queries the configured LLM API for a schema-constrained, evidence-cited triage assessment.
- **Preconditions:**
  1. Target alert exists in PostgreSQL with `status = PENDING_REVIEW`.
  2. LLM provider adapter (`GeminiAdapter` or `ClaudeAdapter`) is initialized with a valid API key.
- **Inputs:**

  - Target `Alert` record from PostgreSQL.
  - Target host's `criticality_tier` from the `assets` table (`FR-9`).
  - Up to `K = 5` correlated historical alerts from PostgreSQL sharing the same `agent_id` or `src_ip` within lookback window `W` (default `24 hours`).
  - Up to `2` active few-shot override exemplars retrieved via `FR-4`.
- **Processing:**
  1. **Evidence Pack Assembly:** Build a structured JSON `EvidencePack` comprising:
     - `alert_metadata`: `wazuh_alert_id`, `timestamp`, `rule.id`, `rule.level`, `rule.description`, `rule.mitre` (tactics and technique IDs).
     - `asset_context`: `agent_id`, `agent_name`, `criticality_tier` (`LOW`, `MEDIUM`, `HIGH`, `CRITICAL`).
     - `telemetry_payload`: Nested and dot-notation map of alert payload fields (`data.*`, `syscheck.*`, `full_log`).
     - `temporal_context`: Summary list of up to `K = 5` recent alerts from the same host/IP in the last `24 hours`.
  2. **Prompt-Injection Sanitization:** Process all untrusted string values through `PromptSanitizer`:
     - Strip control characters, null bytes, and delimiter-spoofing sequences (such as `</system>`, code fences, `[INST]`, `Human:`, `System:`).
     - Scan for adversarial override phrases (e.g., `"ignore previous instructions"`, `"mark this benign"`) and set `injection_suspect = true` in `EvidencePack` metadata if detected.
     - Wrap the sanitized `EvidencePack` inside a strictly delimited read-only JSON envelope with system instructions mandating that all values inside the envelope be treated solely as passive data.
  3. **Schema-Constrained LLM Query:** Dispatch the prompt (system instructions + `FR-4` few-shot exemplars + sanitized `EvidencePack`) to the LLM API with a `10-second` timeout. Enforce parsing into:
     - `verdict`: `TRUE_POSITIVE` | `FALSE_POSITIVE` | `NEEDS_ANALYST_REVIEW`
     - `recommended_severity`: `LOW` | `MEDIUM` | `HIGH` | `CRITICAL`
     - `confidence_score`: Float between `0.0` and `1.0`
     - `cited_evidence_keys`: Array of **dot-notation JSON key paths** from the `EvidencePack` supporting the verdict (e.g., `telemetry_payload.data.win.eventdata.commandLine`, `alert_metadata.rule.mitre.id`)
     - `explanation`: Plain-language justification ($\leq$ `500 characters`), explicitly noting missing or conflicting evidence when abstaining.
  4. **Retry & Fallback:** If the LLM request times out (`> 10s`), fails schema validation, or returns HTTP `429`/`5xx`, retry up to `3` times with exponential backoff (`1s`, `2s`, `4s`). After `3` failed attempts, set alert `status = NEEDS_MANUAL_TRIAGE`.
- **Outputs:**
  - Persisted `EvidencePack` record and raw `AIAssessment` object passed to `FR-3` (or alert status set to `NEEDS_MANUAL_TRIAGE`).

- **Postconditions:**
  - Alert either has a schema-validated `AIAssessment` ready for `FR-3` guardrail checks or is safely routed to `NEEDS_MANUAL_TRIAGE`.
- **Side Effects & Error Handling:**
  - Logs model name, inference latency (ms), and retry count in `ai_assessments`.

3.3 FR-3: Deterministic Safety Floor & Abstention Rules Engine

Attribute	Specification
Requirement ID	`FR-3`
Priority	Essential
Primary Actor	Backend Rules Engine

- **Description:** Evaluates every LLM triage output against deterministic abstention, citation-grounding, and severity safety-floor policies before transitioning the alert to `AWAITING_ANALYST`.
- **Preconditions:**
  1. `FR-2` has produced a parsed `AIAssessment` and `EvidencePack` for a `PENDING_REVIEW` alert.
- **Inputs:**
  - Raw Wazuh `rule_level` (`0` to `15`), `EvidencePack` (valid dot-key set and `injection_suspect` flag), and raw `AIAssessment`.
- **Processing:**
  1. Map baseline Wazuh `rule_level` to Sentra-X severity:
     - `Level 12-15` → `CRITICAL`
     - `Level 8-11` → `HIGH`
     - `Level 4-7` → `MEDIUM`
     - `Level 0-3` → `LOW`
  2. **Abstention & Grounding Rule:** Force `effective_verdict = NEEDS_ANALYST_REVIEW`, set `abstention_triggered = true`, and append an audit note if **any** of the following hold:
     - `confidence_score < 0.60` (configurable threshold).
     - `cited_evidence_keys` is empty or contains any dot-notation path not present in the alert's `EvidencePack`.
     - The LLM output is self-contradictory (`verdict = FALSE_POSITIVE` paired with `HIGH` or `CRITICAL` severity).
     - `EvidencePack.injection_suspect = true` AND the LLM proposed `FALSE_POSITIVE` or `LOW` severity.

3. **Safety Floor Rule:**
   - **Critical Safety Floor (`rule_level` $\geq$ `12`):** If the LLM proposes `verdict = FALSE_POSITIVE` **or** `recommended_severity` in `{LOW, MEDIUM}`, reject the downgrade, enforce `effective_severity = CRITICAL` (or retain `HIGH` if proposed as `HIGH` with `TRUE_POSITIVE`), force `effective_verdict = NEEDS_ANALYST_REVIEW`, set `safety_floor_triggered = true`, and append a Critical Safety Floor audit note.
   - **High-Severity Safety Floor (`rule_level` in `10..11`):** If the LLM proposes `verdict = FALSE_POSITIVE` **or** `recommended_severity = LOW`, reject the downgrade, enforce `effective_severity = HIGH`, force `effective_verdict = NEEDS_ANALYST_REVIEW`, set `safety_floor_triggered = true`, and append a High-Severity Safety Floor audit note.
4. Save raw and post-guardrail fields in `ai_assessments` and update `alerts.status = AWAITING_ANALYST`.

- **Outputs:**
  - Finalized `ai_assessments` row and alert transitioned to `AWAITING_ANALYST`.
- **Postconditions:**
  - High/Critical SIEM detections cannot be silently downgraded or dismissed, and ungrounded/low-confidence assessments default safely to `NEEDS_ANALYST_REVIEW`.
- **Side Effects & Error Handling:**
  - Updates guardrail intervention counters used by `FR-7`.

3.4 FR-4: Dynamic Few-Shot Feedback Calibration

Attribute	Specification
Requirement ID	`FR-4`
Priority	Essential
Primary Actor	SOC Analyst / SOC Team Lead / Triage Agent

- **Description:** Persists human override rationales and dynamically retrieves the top 2 contextually matching active exemplars as few-shot reference cases during future prompt assembly without retraining LLM weights.
- **Preconditions:**
  1. For storage: An `Analyst` submits an `OVERRIDE` or a `TeamLead` resolves an escalation with a mandatory justification ($\geq$ `10 characters`).
  2. For retrieval: `FR-2` is building a prompt for a `PENDING_REVIEW` alert.
- **Inputs:**

  - **Storage:** `alert_id`, `rule_id`, `process_signature`, `asset_criticality`, `calibrated_verdict`, `calibrated_severity`, `rationale` (≥ `10 chars`), `user_id`.
  - **Retrieval:** Candidate alert's `rule_id`, `process_signature`, and `asset_criticality`.
  - **Governance:** `exemplar_id` and `is_active` boolean toggle from a `TeamLead`.
- **Processing:**
  1. **Exemplar Storage:** Insert override record into `feedback_exemplars` with `is_active = true`.
  2. **Tiered Retrieval (`< 50ms`):** Query up to `2` most recent active (`is_active = true`) exemplars in two tiers:
     - *Tier 1 (Exact Context Match):* Same `rule_id` **AND** matching `process_signature`.
     - *Tier 2 (Rule + Asset Tier Fallback):* If Tier 1 returns `< 2` rows, fill remaining slots matching `rule_id` **AND** `asset_criticality`, prepending a prompt caution instructing the LLM to verify command/IP similarity before applying the exemplar.
  3. **Exemplar Revocation:** Allow `TeamLead` users to set `is_active = false` on any erroneous exemplar so it is immediately excluded from future prompts.
- **Outputs:**
  - Up to `2` structured few-shot exemplars injected into `FR-2` and recorded in `evidence_packs.injected_exemplar_ids`.
- **Postconditions:**
  - Recurring benign scripts or environment-specific alerts are calibrated in-context while remaining bounded by `FR-3` safety floors.
- **Side Effects & Error Handling:**
  - Increments `match_hit_count` on retrieved exemplars; gracefully falls back to zero-shot triage if no exemplars match.

3.5 FR-5: Prioritized Analyst Review Queue & Evidence Trace Modal

Attribute	Specification
Requirement ID	`FR-5`
Priority	Essential
Primary Actor	SOC Analyst, SOC Team Lead

- **Description:** Displays actionable alerts sorted by severity and age, and provides a split-pane detail modal highlighting cited dot-notation evidence keys, raw logs, guardrail audit notes, and injected few-shot exemplars.

- **Preconditions:**
  1. User is logged in with a valid JWT (`Analyst`, `TeamLead`, or `Admin`).
- **Inputs:**
  - Queue filter parameters (`status`, `severity`, `rule_id`, search term, page number) or selected `alert_id`.
- **Processing:**
  1. Query alerts in `AWAITING_ANALYST` and `NEEDS_MANUAL_TRIAGE` states by default (plus an `ESCALATED` tab for `TeamLead` users), ordered by effective severity (`CRITICAL` → `HIGH` → `MEDIUM` → `LOW`) and then by `ingested_at` ascending (oldest first).
  2. Render queue rows displaying: Wazuh Rule ID/Name, Hostname & Asset Criticality badge, AI Verdict badge (or `Manual Triage Required`), Confidence Score badge, Safety Floor/Abstention indicator, and truncated explanation.
  3. On row click, open the **Alert Detail & Evidence Modal** displaying:
     - Full `EvidencePack` tree with visual highlight badges on every key path present in `cited_evidence_keys`.
     - Raw Wazuh JSON log excerpt and MITRE ATT&CK technique pills.
     - Guardrail alert banner if `safety_floor_triggered` or `abstention_triggered` is true.
     - Injected historical few-shot exemplars (`FR-4`).
- **Outputs:**
  - Interactive prioritized triage table and Alert Detail & Evidence Modal.
- **Postconditions:**
  - Analysts can verify the exact telemetry backing an AI assessment without reading unformatted JSON logs.
- **Side Effects & Error Handling:**
  - Read-only view; displays skeleton loaders and clear error banners on API timeout.

3.6 FR-6: Analyst & Team Lead Decision Capture

Attribute	Specification
Requirement ID	`FR-6`
Priority	Essential
Primary Actor	SOC Analyst, SOC Team Lead

- **Description:** Records human triage dispositions (`Approve`, `Override`, `Escalate`, `Retry AI`, `Manual Triage Closure`, `Resolve Escalation`), updates alert status, and commits an immutable audit trail.

- **Preconditions:**
  1. Authenticated `Analyst` or `TeamLead` has opened an actionable alert (`AWAITING_ANALYST`, `NEEDS_MANUAL_TRIAGE`, or `ESCALATED`).
- **Inputs:**
  - `alert_id`, `action_taken`, `final_verdict` (`TRUE_POSITIVE` | `FALSE_POSITIVE`), `final_severity` (`LOW` | `MEDIUM` | `HIGH` | `CRITICAL`), and `rationale`.
- **Processing:**
  1. Enforce role and state transition rules:
     - **Approve (`AWAITING_ANALYST`):** Accepts effective AI severity and verdict (if AI verdict was `NEEDS_ANALYST_REVIEW`, analyst selects final `TRUE_POSITIVE` or `FALSE_POSITIVE`). Sets status to `CLOSED`.
     - **Override (`AWAITING_ANALYST`):** Requires selecting alternate severity/verdict and a mandatory `rationale` ($\geq$ `10 characters`). Sets status to `CLOSED` and creates an `FR-4` exemplar.
     - **Escalate (`AWAITING_ANALYST` or `NEEDS_MANUAL_TRIAGE`):** Sets status to `ESCALATED`.
     - **Retry AI Triage (`NEEDS_MANUAL_TRIAGE`):** Resets retry count and sets status to `PENDING_REVIEW`.
     - **Manual Triage Closure (`NEEDS_MANUAL_TRIAGE`):** Requires manual severity, binary verdict, and mandatory `rationale` ($\geq$ `10 characters`). Sets status to `CLOSED`.
     - **Resolve Escalation (`ESCALATED`, `TeamLead` only):** Requires authoritative severity, binary verdict, and mandatory `rationale` ($\geq$ `10 characters`). Sets status to `CLOSED` and optionally creates a verified `FR-4` exemplar.
  2. Commit status change and append an immutable record to `analyst_decisions_audit` in a single atomic transaction.
- **Outputs:**
  - HTTP `200 OK` with updated alert state and `audit_id`.
- **Postconditions:**
  - Alert transitions to `CLOSED`, `ESCALATED`, or `PENDING_REVIEW`, and an immutable audit entry is persisted.
- **Side Effects & Error Handling:**
  - Returns HTTP `422 Unprocessable Entity` (rendered as an inline error banner) if `rationale` is `< 10 characters` when required; returns HTTP `403 Forbidden` on unauthorized role actions.

3.7 FR-7: Agreement & Guardrail Analytics Reporting

Attribute	Specification
Requirement ID	`FR-7`
Priority	Essential
Primary Actor	SOC Team Lead

- **Description:** Provides an analytics dashboard and CSV export quantifying AI-analyst agreement rates, severity override deltas, guardrail interventions, and few-shot calibration trends over a configurable date range (up to 90 days).
- **Preconditions:**
  1. User is authenticated with `TeamLead` or `Admin` role.
- **Inputs:**
  - `start_date`, `end_date` ($\leq$ `90 days`), optional `rule_id` filter, or CSV export trigger.
- **Processing:**
  1. Compute aggregate metrics over closed and escalated alerts in the date window:
     - Total alerts closed, `% Approved` without modification, `% Overridden` (grouped by severity delta and TP/FP flip), `% Escalated`, and `% Manually Triaged`.
     - Count and `%` of alerts where **Safety Floor** (`safety_floor_triggered`) or **Abstention** (`abstention_triggered`) intervened.
     - Daily/weekly **Override Rate Trendline** to evaluate whether `FR-4` few-shot calibration reduces repeat overrides over time.
  2. Generate downloadable CSV reports of single-day or date-range decisions within $\leq$ `10 seconds`.
- **Outputs:**
  - JSON analytics summary rendered as charts within $\leq$ `5 seconds` (up to `50,000` closed alerts) and streaming `.csv` export file.
- **Postconditions:**
  - Team Leads can audit AI reliability, guardrail activity, and calibration progress.
- **Side Effects & Error Handling:**
  - Rejects requests from `Analyst` accounts with HTTP `403 Forbidden`.

3.8 FR-8: User Authentication & Role-Based Access Control (RBAC)

Attribute	Specification
Requirement ID	FR-8
Priority	Essential
Primary Actor	All Users (Analyst, TeamLead, Admin)

- **Description:** Enforces salted bcrypt password authentication and JWT-based role authorization across all API endpoints and UI routes.
- **Preconditions:**
  1. User account is registered in users with is_active = true and a single assigned role (Analyst, TeamLead, or Admin).
- **Inputs:**
  - Login credentials (username/email + password) or HTTP Authorization: Bearer <JWT> header.
- **Processing:**
  1. Verify login password against stored bcrypt hash (cost $\geq$ 10).
  2. Issue a signed JWT containing sub (user_id), role, iat, and exp.
  3. Verify JWT validity and role permissions on every protected API endpoint.
  4. **User Account Administration (Admin only):** Create user accounts (username, email, initial password hashed with bcrypt, role), assign or change a single role, and activate or deactivate accounts. Deactivated users cannot log in, and their existing JWTs are rejected because is_active is re-checked on verification. Non-Admin callers receive HTTP 403 Forbidden.
- **Outputs:**
  - Signed JWT on valid login; HTTP 401 Unauthorized on missing/expired token; HTTP 403 Forbidden on role mismatch.
- **Postconditions:**
  - Role-restricted actions and analytics routes are isolated by user role.
- **Side Effects & Error Handling:**
  - Records failed login attempts in application security logs.

3.9 FR-9: Host & Asset Criticality Registry

Attribute	Specification
Requirement ID	FR-9
Priority	Conditional
Primary Actor	SOC Team Lead, System Administrator

- **Description:** Maintains host criticality tiers (LOW, MEDIUM, HIGH, CRITICAL) for monitored Wazuh agents to enrich FR-2 Evidence Packs and FR-4 tiered exemplar matching.

- **Preconditions:**
  1. User is authenticated as `TeamLead` or `Admin` for write operations.
- **Inputs:**
  - `agent_id`, `hostname`, `ip_address`, `criticality_tier` (`LOW` | `MEDIUM` | `HIGH` | `CRITICAL`), and optional `description`.
- **Processing:**
  1. Auto-insert unseen Wazuh `agent.id` values with `criticality_tier = MEDIUM` during `FR-1` ingestion.
  2. Allow `TeamLead` and `Admin` users to view and update asset criticality tiers via the dashboard.
- **Outputs:**
  - Updated `assets` row in PostgreSQL.
- **Postconditions:**
  - Subsequent Evidence Packs for that `agent_id` include the updated criticality tier.
- **Side Effects & Error Handling:**
  - Records the modifying user and timestamp in `updated_by` and `updated_at` of the `assets` row (Section 7.2).

3.10 FR-10: Adversarial & Baseline Evaluation Runner

Attribute	Specification
Requirement ID	`FR-10`
Priority	Conditional (Research Verification)
Primary Actor	System Administrator / Evaluator

- **Description:** Replays benchmark alert datasets (including the 30-payload adversarial prompt-injection suite) under baseline raw-LLM and full Sentra-X modes to compute comparative evaluation metrics.
- **Preconditions:**
  1. Triggered by an `Admin` user or CLI command with a labeled JSON/JSONL benchmark dataset.
- **Inputs:**
  - Benchmark dataset (`raw_alert`, `expected_verdict`, `expected_severity`, `is_prompt_injection`) and pipeline mode (`BASELINE_RAW_LLM` vs. `SENTRAX_FULL`).
- **Processing:**
  1. Run each benchmark alert through the selected pipeline mode in an isolated evaluation context.

2. Calculate TP/FP Precision, Recall, F1, False-Negative Rate, Abstention Accuracy, Safety Floor Trigger Rate, Mean Latency (ms), and Prompt-Injection Success Rate (%).

- **Outputs:**
  - Comparative JSON and Markdown/CSV evaluation report.
- **Postconditions:**
  - Reproducible research evaluation tables are generated without polluting production audit tables.
- **Side Effects & Error Handling:**
  - Throttles batch requests to respect hosted LLM API rate limits.

Chapter 4

External Interface Requirements

4.1 User Interfaces

The dashboard is a browser-based React.js Single-Page Application supporting `1920x1080` and `1366x768` desktop viewports: 1. **Login Screen (`/login`):** JWT authentication gate with inline error banners. 2. **Prioritized Triage Queue (`/queue`):** Sortable, filterable table with tabs for `Awaiting Review` (`AWAITING_ANALYST` + `NEEDS_MANUAL_TRIAGE`), `Escalated` (`ESCALATED`), and `Closed` (`CLOSED`), displaying severity badges, asset criticality badges, confidence indicators, and safety-floor shields. 3. **Alert Detail & Evidence Modal:** Split-pane inspector showing the AI summary, confidence score, guardrail notes, injected few-shot exemplars, and the structured `EvidencePack` with visual highlights on every dot-notation key in `cited_evidence_keys`, alongside context-aware decision buttons (`Approve`, `Override`, `Escalate`, `Retry AI`, `Resolve Escalation`). 4. **Team Lead Analytics & Governance View (`/analytics`, `/governance`):** Interactive charts for agreement rates, override severity deltas, override-rate trendlines over time, safety floor/abstention counts, CSV export, Asset Criticality management (`FR-9`), and Few-Shot Exemplar revocation (`FR-4`).

4.2 Hardware Interfaces

Sentra-X has no dedicated hardware interface. It runs in Docker containers on a host with at least `4 vCPUs`, `8 GB RAM` (`16 GB` when co-hosting Wazuh), and `20 GB` of SSD storage for the PostgreSQL volume.

4.3 Software Interfaces

External System	Interface / Version	Direction	Purpose & Data Format
Wazuh SIEM / XDR	REST API v4.x / Webhook (`HTTPS JSON`)	Inbound (Read-Only)	Polls `/alerts` or receives webhook events for raw security alert JSON (`FR-1`).
Google Gemini API	`google-genai` SDK / REST (`HTTPS JSON`)	Outbound / Inbound	Sends schema-constrained `EvidencePack` prompts; receives structured triage JSON (`FR-2`).
Anthropic Claude API	`anthropic` SDK / REST (`HTTPS JSON`)	Outbound / Inbound	Swappable alternative LLM provider using strict JSON schema output (`FR-2`).
PostgreSQL 16	SQLAlchemy 2.0 ORM over TCP Port `5432`	Bidirectional	Relational persistence for alerts, Evidence Packs, assessments, audits, exemplars, assets, and users.

4.4 Communication Protocols

- **Dashboard–Backend:** HTTPS (`TLS 1.2+`) with UTF-8 `application/json` payloads and `text/csv` streams for exports.
- **API Authentication:** Stateless Bearer JWT (`Authorization: Bearer <token>`) on all protected endpoints (`FR-8`).
- **Backend–Wazuh:** HTTPS polling authenticated via Wazuh read-only API JWT or HMAC-verified webhook POST requests.
- **Backend–LLM API:** Outbound HTTPS (`TLS 1.2/1.3`) with a strict `10-second` request timeout and exponential backoff retry logic.

Chapter 5

Non-Functional Requirements

NFR ID	Category	Metric / Requirement Summary	Target Threshold
NFR-1	Performance	End-to-end alert triage latency (PENDING_REVIEW → AWAITING_ANALYST)	$\leq$ 8.0 seconds
NFR-2	Availability	Backend & dashboard service uptime over a 30-day evaluation window	$\geq$ 99.0% ($\leq$ 7.3h downtime)
NFR-3	Security	Prompt-injection bypass rate across 30 malicious log payloads; bcrypt cost	0% bypass; bcrypt cost $\geq$ 10
NFR-4	Auditability	Audit retention period; CSV export speed; top-50 exemplar lookup latency	$\geq$ 12 months; $\leq$ 10s CSV; < 50ms lookup
NFR-5	Scalability	Sustained ingestion throughput; maximum PENDING_REVIEW backlog; 50k analytics render	$\geq$ 5 alerts/sec; $\leq$ 500 backlog; $\leq$ 5s render
NFR-6	Maintainability	LLM provider switching (Gemini $\leftrightarrow$ Claude) and full stack deployment	Config-only switch; single docker compose up

5.1 Performance Requirements (NFR-1)

The triage latency target of NFR-1 covers the whole pipeline: Evidence Pack compilation, sanitization, exemplar lookup (FR-4), the LLM query, and FR-3 rules verification. Exemplar lookup, analytics rendering (up to 50,000 closed alerts), and CSV export shall meet the thresholds of NFR-4 and NFR-5 in the table above.

5.2 Reliability & Availability Requirements (NFR-2)

- The backend and dashboard containers shall maintain $\geq$ **99.0% uptime** over a 30-day window, enforced via Docker health checks and automatic container restart policies.
- Unreachable Wazuh endpoints or LLM API timeouts shall never crash the ingestion loop; failed LLM calls after 3 retries shall deterministically transition the alert to NEEDS_MANUAL_TRIAGE.

5.3 Security & Adversarial Robustness Requirements (NFR-3)

- All dashboard and API traffic shall use HTTPS (TLS 1.2+), and user passwords shall be hashed using salted **bcrypt** (cost factor $\geq$ 10).
- Untrusted telemetry strings must be structurally isolated from system instructions using strict JSON encapsulation (FR-2). Evaluated against a benchmark of **30 malicious prompt-injection payloads**, the **prompt-injection success/bypass rate shall be 0%**.
- Audit records in analyst_decisions_audit shall be immutable (append-only).

5.4 Usability Requirements

- Cited evidence keys in cited_evidence_keys shall be visually highlighted inside the Alert Detail Modal so analysts can verify AI reasoning without scanning raw JSON logs.
- Approving an alert shall require at most **2 clicks** from the queue view, and all validation errors (HTTP 422) shall render as clear inline banners.

5.5 Scalability Requirements (NFR-5)

Ingestion throughput and backlog shall meet the NFR-5 thresholds above, and PostgreSQL storage and indexing shall support a minimum **12-month retention window** (NFR-4).

5.6 Maintainability & Portability Requirements (NFR-6)

- Switching between Google Gemini and Anthropic Claude shall require only changing environment variables (LLM_PROVIDER and API key) without code changes.
- The complete stack shall run across Linux and Windows/macOS Docker Desktop environments via Docker Compose.

5.7 Domain-Specific Requirements

These requirements arise from the Security Operations Center (SOC) and SIEM domain rather than from general software qualities.

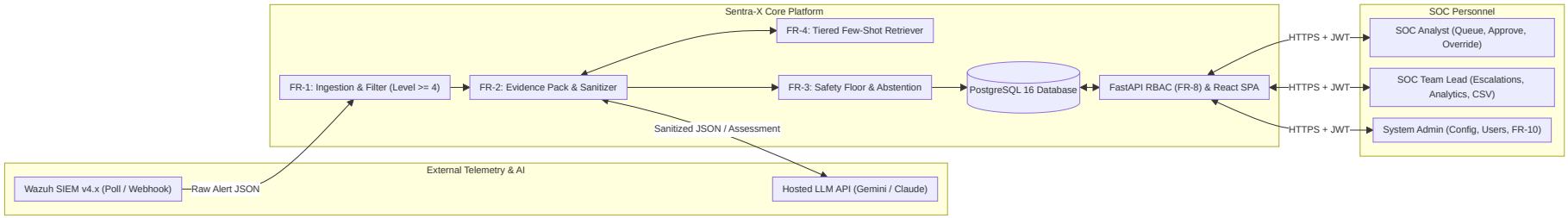
ID	Domain-Specific Requirement	Domain Basis	Verification
DR-1	Wazuh rule levels 0–15 shall be mapped to severities (0-3 LOW, 4-7 MEDIUM, 8-11 HIGH, 12-15 CRITICAL), and the original Wazuh level shall be retained unaltered in alerts.rule_level.	Wazuh rule-level scale (FR-3)	Boundary unit tests
DR-2	MITRE ATT&CK tactic and technique identifiers from rule.mitre shall be preserved in the Evidence Pack and displayed to analysts.	MITRE ATT&CK taxonomy	UI inspection
DR-3	The AI verdict vocabulary shall be limited to TRUE_POSITIVE, FALSE_POSITIVE, and NEEDS_ANALYST_REVIEW; the final human verdict shall be binary (TRUE_POSITIVE or FALSE_POSITIVE).	SOC triage practice	Schema validation
DR-4	Every endpoint-originated log field (full_log, command lines, user names, URLs) shall be treated as untrusted input.	Indirect prompt-injection threat model (§8.3)	30-payload injection test
DR-5	High/Critical detections (rule_level $\geq$ 10) shall never be silently dismissed or downgraded by AI inference.	SOC risk policy (FR-3)	Safety Floor boundary tests
DR-6	Sentra-X shall be read-only toward Wazuh: no active-response, rule modification, or agent configuration changes.	SIEM separation of duties (§8.1)	Integration test and code review
DR-7	The final disposition of every alert shall be recorded by an authenticated human.	SOC accountability (§8.3)	State-transition test
DR-8	The Wazuh alert ID shall be the unique idempotency key for an incoming alert.	Wazuh alert format (FR-1)	Deduplication test
DR-9	All alert and decision timestamps shall be stored in UTC, and audit records shall be retained for at least 12 months.	Audit and forensic practice (NFR-4)	Database inspection
DR-10	Raw telemetry shall remain in the local database; only sanitized, encrypted prompt payloads may be sent to the LLM API.	Data residency (§8.3)	Outbound payload review

Chapter 6

System Models

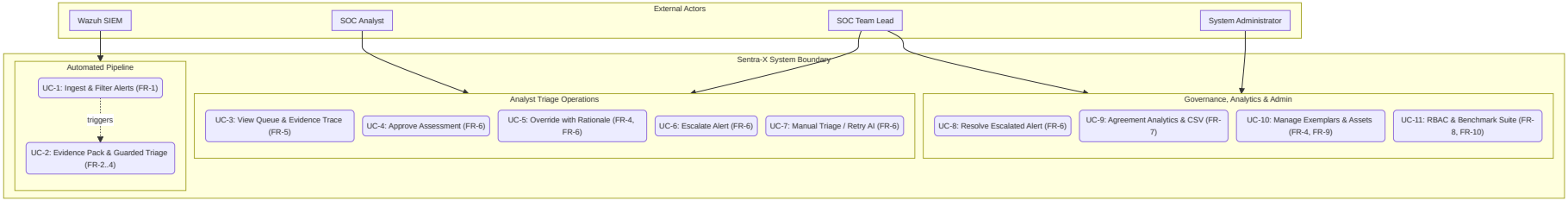
6.1 System Context Model

The System Context Model illustrates how Sentra-X sits between the monitored Wazuh SIEM environment, the swappable Hosted LLM API (Gemini or Claude), and the three human SOC user roles.



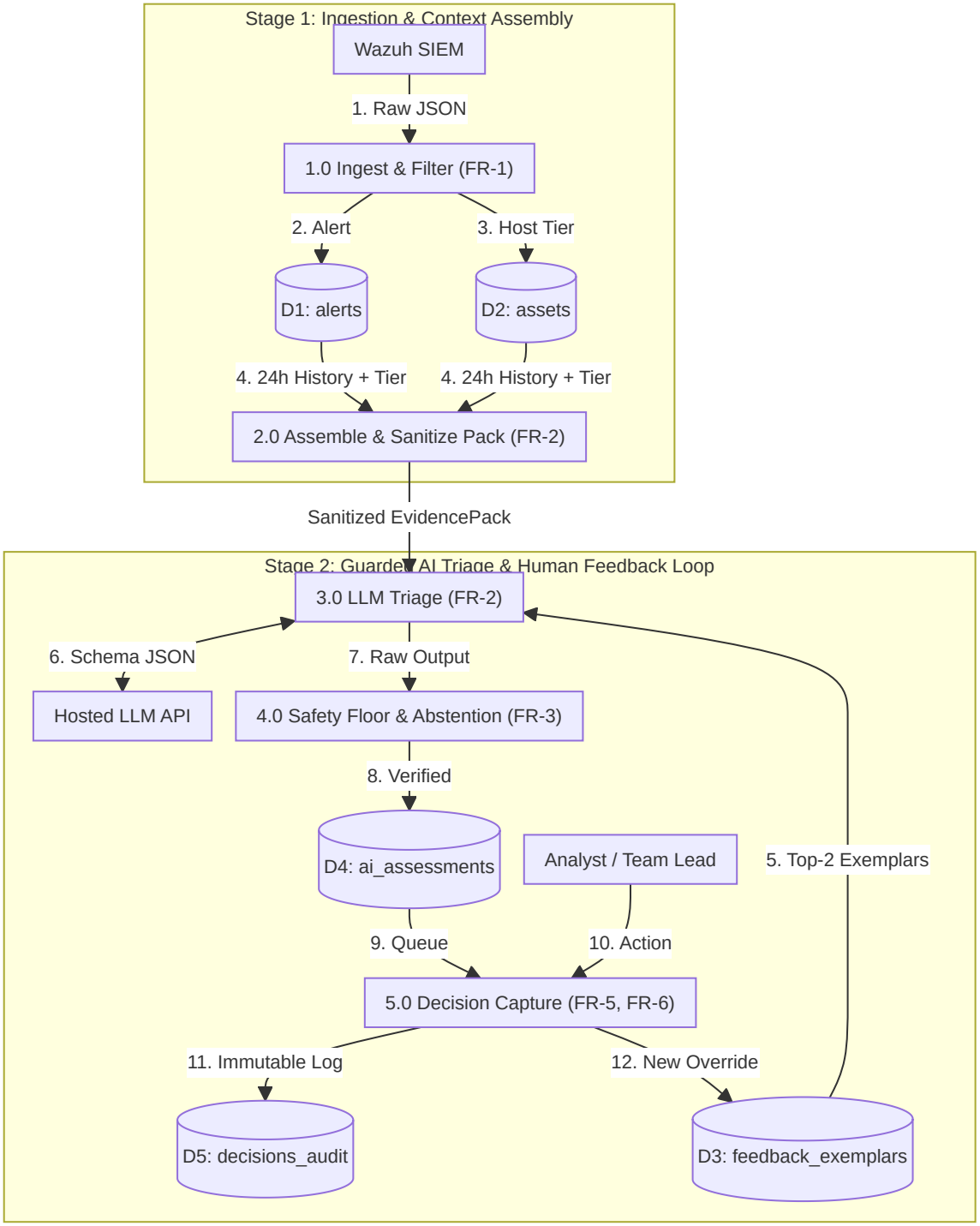
6.2 Use Case Model

The Use Case Model groups Sentra-X's 11 core use cases (`UC-1` through `UC-11`) across automated background pipelines, SOC Analyst triage operations, and Team Lead / Administrator governance.



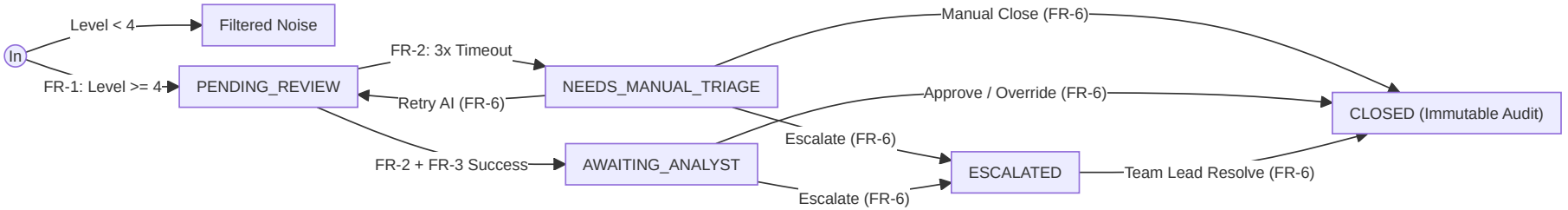
6.3 Data Flow Model (DFD Level 1)

The Level-1 Data Flow Diagram traces how untrusted Wazuh telemetry is enriched, sanitized, evaluated by the LLM, filtered by deterministic safety rules, and calibrated via human feedback.



6.4 Alert Lifecycle State Model

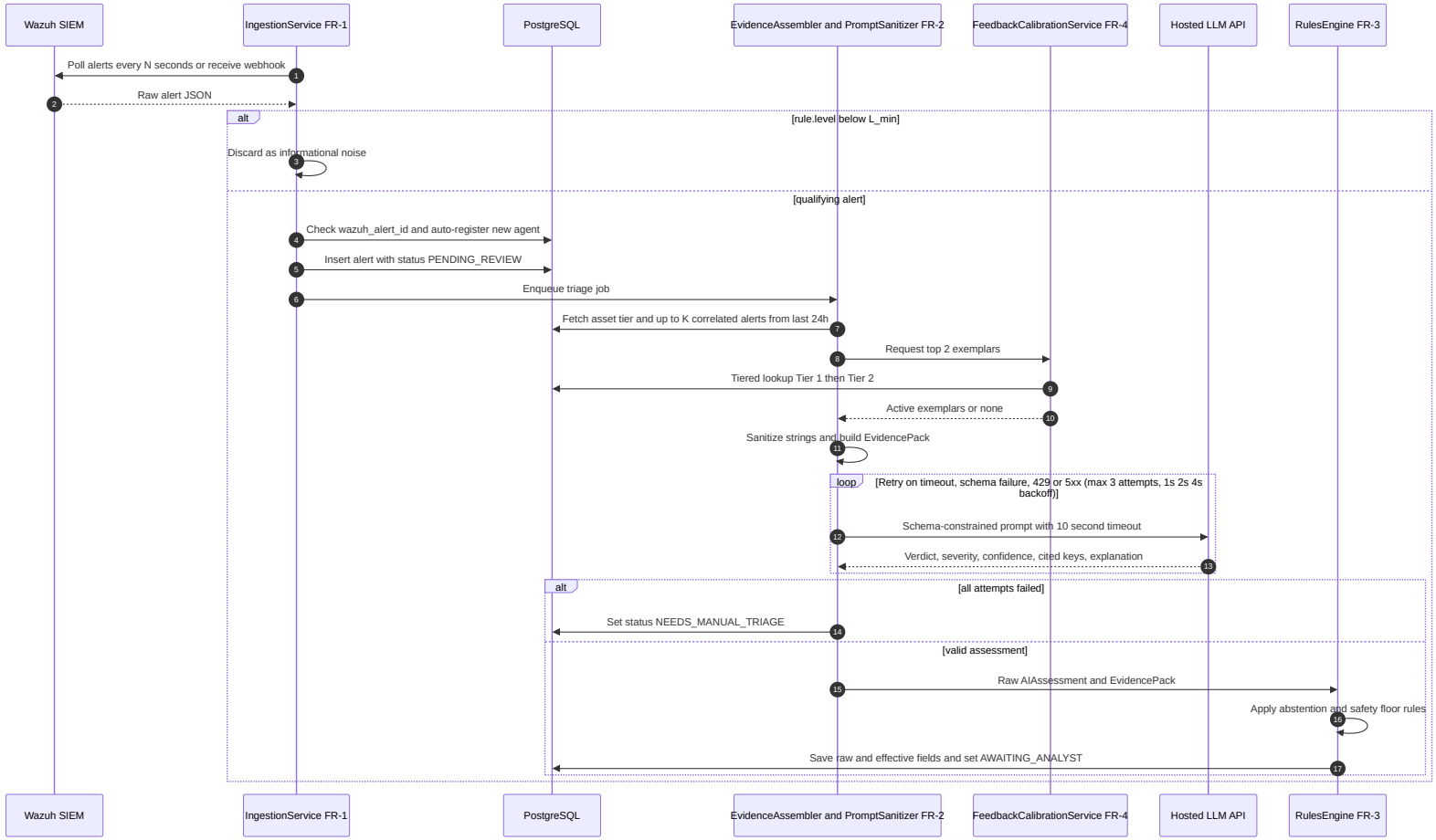
Every ingested alert transitions through a deterministic, closed-loop state machine with zero orphaned states.



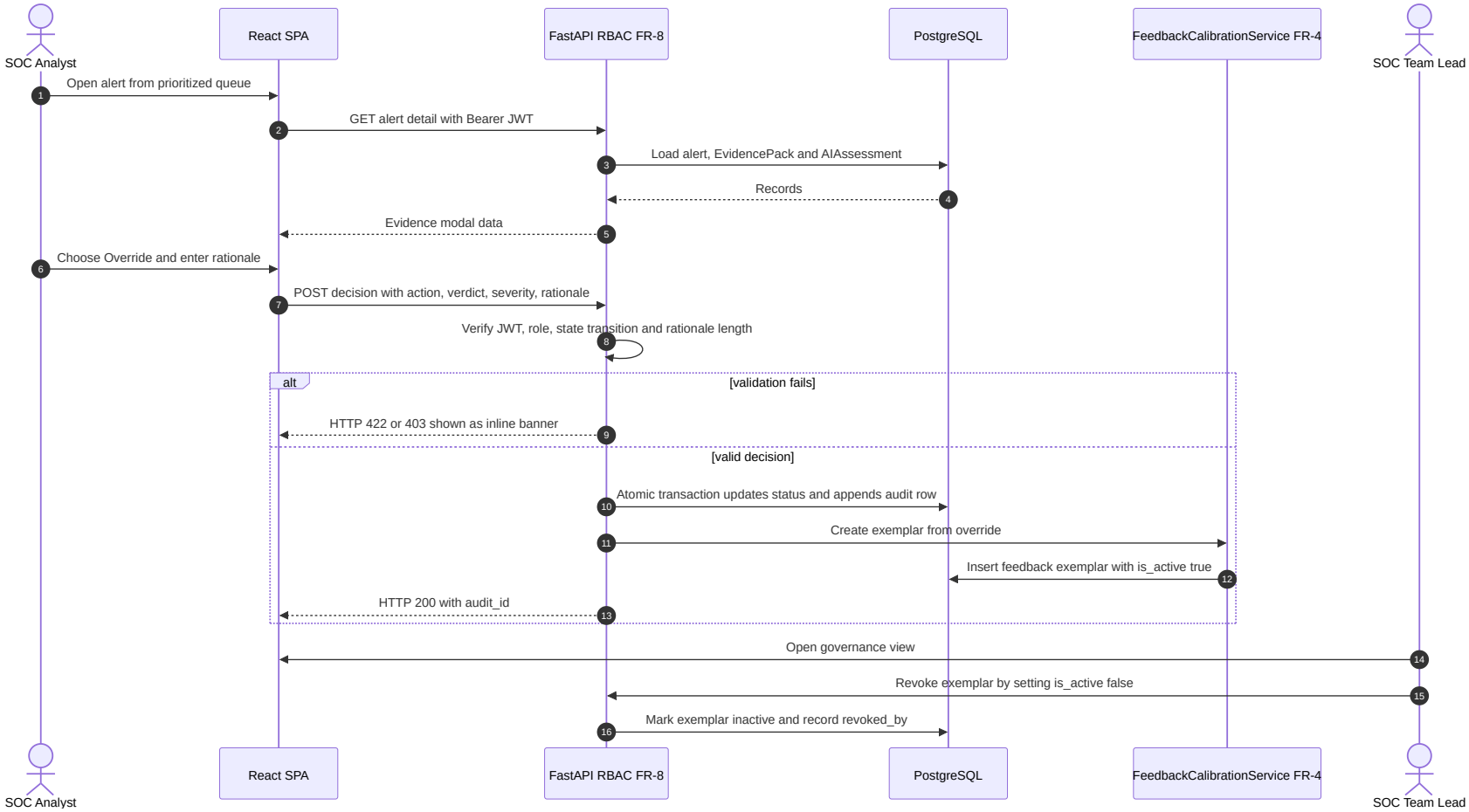
6.5 Interaction Model (Sequence Diagrams)

The sequence diagrams below show the time-ordered interactions among actors, containers, and external systems. The first covers the automated pipeline (`UC-1`, `UC-2`); the second covers analyst decision capture and the feedback loop (`UC-3`, `UC-5`, `UC-10`).

Sequence 1: Automated Ingestion and Guarded Triage

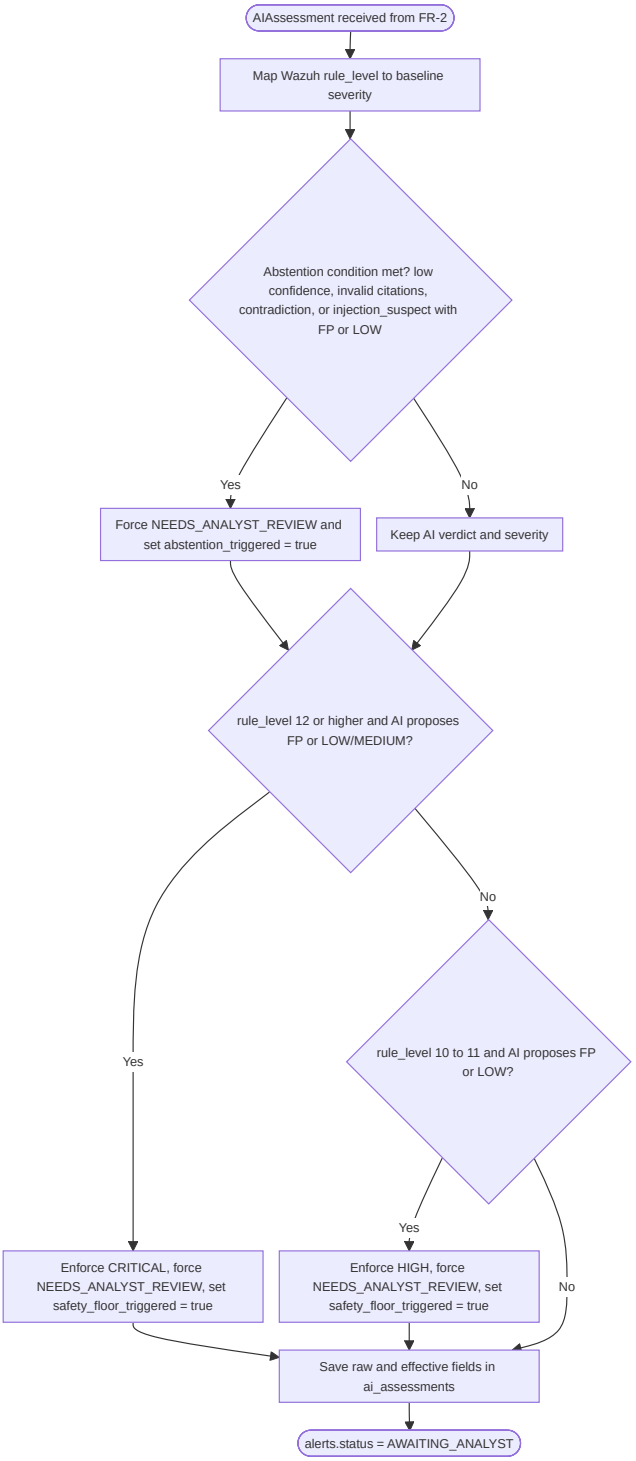


Sequence 2: Analyst Decision Capture and Feedback Loop



6.6 Behavioral Model (Guardrail Decision Activity Flow)

The activity flow below models the dynamic behavior of the deterministic guardrail engine (FR-3) for every AI assessment. Exact rule conditions are specified in Section 3.3.



6.7 Use Case Specifications

The table below gives the textual specification of each use case in the Use Case Model (Section 6.2).

UC	Name / Actor	Preconditions	Main Flow	Alternate / Exception Flows	Postconditions
UC-1	Ingest & Filter Alerts / Wazuh SIEM, System Timer	Backend and database healthy; Wazuh endpoint, `N`, `L_min` configured.	1. Poll or receive alert. 2. Check `rule.level` $\geq$ `L_min`. 3. Deduplicate by `wazuh_alert_id`. 4. Extract metadata; auto-register unseen agent. 5. Persist with `PENDING_REVIEW`.	A1: `rule.level` $<$ `L_min` $\rightarrow$ discarded, no LLM call. A2: duplicate ID $\rightarrow$ skipped. A3: Wazuh unreachable $\rightarrow$ warning logged, retry next cycle.	Alert stored and triage job queued.
UC-2	Compile Evidence Pack & Run Guarded Triage / Triage Engine, Hosted LLM	Alert in `PENDING_REVIEW`; LLM adapter configured.	1. Assemble Evidence Pack. 2. Retrieve up to 2 exemplars. 3. Sanitize strings; flag `injection_suspect`. 4. Query LLM under schema. 5. Apply abstention and safety floor. 6. Save and set `AWAITING_ANALYST`.	A1: timeout, schema failure, `429`/`5xx` $\rightarrow$ up to 3 retries, then `NEEDS_MANUAL_TRIAGE`. A2: no exemplar $\rightarrow$ zero-shot prompt. A3: `injection_suspect` with FP/LOW $\rightarrow$ forced `NEEDS_ANALYST_REVIEW`.	Guardrail-checked assessment stored, or alert routed to manual triage.
UC-3	Inspect Prioritized Queue & Evidence Trace / SOC Analyst, Team Lead	User logged in with valid JWT.	1. Open `/queue` (sorted by severity, then age). 2. Filter or search. 3. Click a row. 4. Review highlighted evidence, guardrail notes, exemplars.	A1: API timeout $\rightarrow$ skeleton loader then error banner. A2: missing/expired JWT $\rightarrow$ `401`, redirect to `/login`.	Analyst informed; no state change.
UC-4	Approve AI Assessment / SOC Analyst, Team Lead	Alert `AWAITING_ANALYST` opened.	1. Click `Approve`. 2. If AI verdict was `NEEDS_ANALYST_REVIEW`, select `TRUE_POSITIVE` or `FALSE_POSITIVE`. 3. System sets `CLOSED` and appends audit row atomically.	A1: unauthorized role $\rightarrow$ `403`. A2: invalid state transition $\rightarrow$ rejected.	Alert `CLOSED`; audit row persisted.
UC-5	Override with Rationale / SOC Analyst	Alert `AWAITING_ANALYST` opened.	1. Select alternate verdict/severity. 2. Enter `rationale` $\geq$ `10 chars`. 3. Submit. 4. System closes alert, appends audit, creates exemplar.	A1: rationale $<$ `10` characters $\rightarrow$ `422` inline banner, no change.	Alert `CLOSED`; active exemplar created.
UC-6	Escalate Alert / SOC Analyst	Alert `AWAITING_ANALYST` or `NEEDS_MANUAL_TRIAGE`.	1. Click `Escalate`. 2. System sets `ESCALATED` and appends audit row.	A1: unauthenticated or unauthorized $\rightarrow$ `401`/`403`.	Alert visible in Team Lead `Escalated` tab.
UC-7	Manual Triage or Retry AI / SOC Analyst	Alert `NEEDS_MANUAL_TRIAGE`.	**Retry:** 1. Click `Retry AI`; 2. retry count reset; 3. status `PENDING_REVIEW`. **Manual closure:** 1. Enter severity, binary verdict, rationale; 2. submit; 3. status `CLOSED`.	A1: manual rationale $<$ `10` chars $\rightarrow$ `422`. A2: retry fails again $\rightarrow$ back to `NEEDS_MANUAL_TRIAGE`.	Alert re-queued for AI, or `CLOSED` with audit row.

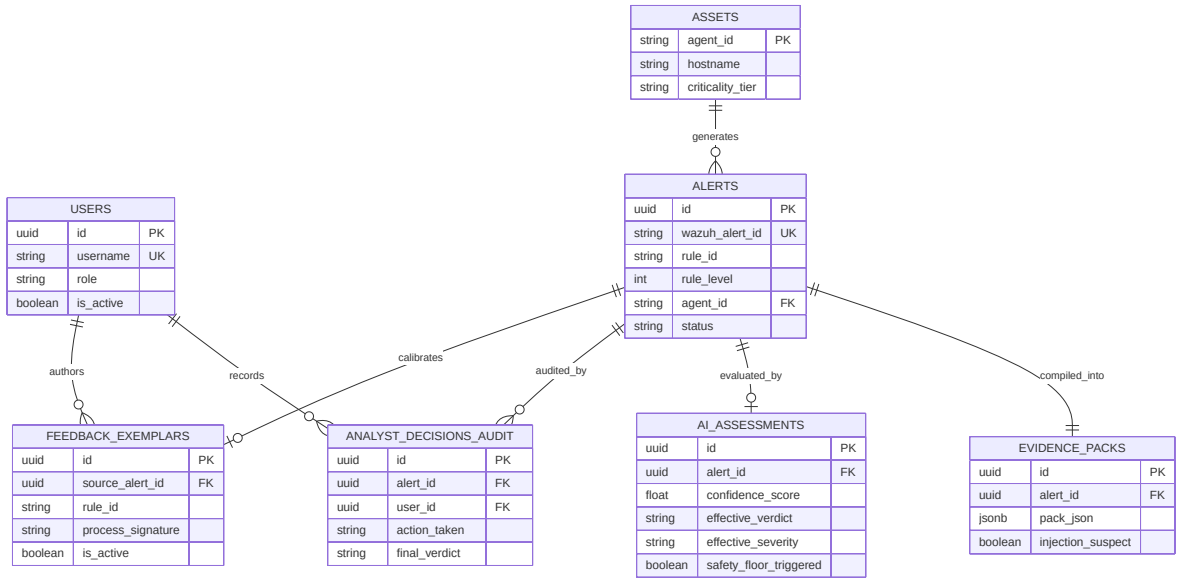
UC	Name / Actor	Preconditions	Main Flow	Alternate / Exception Flows	Postconditions
UC-8	Resolve Escalated Alert / SOC Team Lead	Alert ESCALATED; user has TeamLead role.	1. Open Escalated tab and alert. 2. Review evidence. 3. Enter authoritative severity, verdict, rationale. 4. Submit; system sets CLOSED, appends audit, optionally creates exemplar.	A1: Analyst role → 403. A2: rationale < 10 chars → 422.	Alert CLOSED with authoritative disposition.
UC-9	View Agreement Analytics & CSV / SOC Team Lead, Admin	User has TeamLead or Admin role.	1. Choose date range (≤ 90 days) and optional rule_id. 2. System aggregates metrics. 3. Charts rendered. 4. Optionally export CSV.	A1: range > 90 days → 422. A2: Analyst role → 403.	Metrics displayed or CSV downloaded.
UC-10	Curate Exemplars & Assets / SOC Team Lead (Admin for assets)	Authenticated TeamLead (or Admin for assets).	1. Open /governance. 2. Update asset criticality tier **or** toggle exemplar is_active = false. 3. System persists change and records user and timestamp.	A1: unauthorized role → 403. A2: invalid tier value → 422.	New tier used by next Evidence Pack; revoked exemplar excluded from future prompts.
UC-11	Manage Users, Config & Benchmark / System Administrator	Authenticated Admin.	1. Create/deactivate users and assign roles. 2. Update deployment configuration (Wazuh connection, N, L_min, LLM provider). 3. Select benchmark dataset and mode (BASELINE_RAW_LLM / SENTRAX_FULL). 4. Receive evaluation report.	A1: LLM rate limit during benchmark → batch throttled. A2: non-Admin caller → 403.	Users/configuration updated; evaluation report generated without touching production audit tables.

Chapter 7

Data Requirements

7.1 Logical Data Model (Entity-Relationship Diagram)

The Entity-Relationship diagram below shows the seven core PostgreSQL tables and their cardinality relationships (full column definitions follow in Section 7.2).



7.2 Relational Database Schema & Data Dictionary

The schema consists of seven tables: `users` (RBAC accounts, `FR-8`), `assets` (host criticality, `FR-9`), `alerts` (ingested alerts and lifecycle state, `FR-1`, `FR-5`), `evidence_packs` (sanitized packs and valid citation keys, `FR-2`), `ai_assessments` (raw and post-guardrail results, `FR-2`, `FR-3`), `analyst_decisions_audit` (append-only audit log, `FR-6`), and `feedback_exemplars` (verified override rationales, `FR-4`).

7.2.1 Column-Level Data Dictionary

Data types, nullability, and constraints for every column (PostgreSQL 16). All timestamps are `TIMESTAMPTZ` stored in UTC.

Table	Column	Data Type	Nullable	Constraints / Notes
users	id	UUID	No	Primary key
users	username	VARCHAR(64)	No	UNIQUE
users	email	VARCHAR(255)	No	UNIQUE
users	password_hash	VARCHAR(255)	No	Salted bcrypt, cost $\geq$ 10
users	role	VARCHAR(16)	No	CHECK in (Analyst, TeamLead, Admin)
users	is_active	BOOLEAN	No	Default true
assets	agent_id	VARCHAR(32)	No	Primary key (Wazuh agent ID)
assets	hostname	VARCHAR(255)	No	
assets	ip_address	INET	Yes	
assets	criticality_tier	VARCHAR(8)	No	Default MEDIUM; CHECK in (LOW, MEDIUM, HIGH, CRITICAL)
assets	description	TEXT	Yes	
assets	updated_by	UUID	Yes	FK users(id); NULL when auto-registered
assets	updated_at	TIMESTAMPTZ	No	Default now()
alerts	id	UUID	No	Primary key
alerts	wazuh_alert_id	VARCHAR(64)	No	UNIQUE (deduplication key)
alerts	rule_id	VARCHAR(16)	No	
alerts	rule_level	SMALLINT	No	CHECK between 0 and 15
alerts	rule_description	TEXT	No	
alerts	agent_id	VARCHAR(32)	No	FK assets(agent_id)
alerts	agent_name	VARCHAR(255)	No	
alerts	src_ip	INET	Yes	
alerts	process_signature	VARCHAR(512)	Yes	Normalized from data.win.eventdata.image, syscheck.path, or decoder.name
alerts	raw_payload	JSONB	No	Original Wazuh alert JSON
alerts	alert_timestamp	TIMESTAMPTZ	No	Event time from Wazuh
alerts	ingested_at	TIMESTAMPTZ	No	Default now()
alerts	retry_count	SMALLINT	No	Default 0; reset by Retry AI Triage

Table	Column	Data Type	Nullable	Constraints / Notes
alerts	status	VARCHAR(24)	No	CHECK in (PENDING_REVIEW, AWAITING_ANALYST, NEEDS_MANUAL_TRIAGE, ESCALATED, CLOSED)
evidence_packs	id	UUID	No	Primary key
evidence_packs	alert_id	UUID	No	FK alerts(id), UNIQUE
evidence_packs	pack_json	JSONB	No	Sanitized Evidence Pack
evidence_packs	valid_dot_keys	JSONB	No	Valid citation key set
evidence_packs	injection_suspect	BOOLEAN	No	Default false
evidence_packs	injected_exemplar_ids	JSONB	No	Default []
ai_assessments	id	UUID	No	Primary key
ai_assessments	alert_id	UUID	No	FK alerts(id), UNIQUE
ai_assessments	raw_verdict	VARCHAR(24)	No	Raw LLM output
ai_assessments	raw_severity	VARCHAR(8)	No	Raw LLM output
ai_assessments	confidence_score	REAL	No	CHECK between 0.0 and 1.0
ai_assessments	cited_evidence_keys	JSONB	No	Dot-notation key paths
ai_assessments	explanation	TEXT	No	$\leq$ 500 characters
ai_assessments	effective_verdict	VARCHAR(24)	No	Post-FR-3 result
ai_assessments	effective_severity	VARCHAR(8)	No	Post-FR-3 result
ai_assessments	abstention_triggered	BOOLEAN	No	Default false
ai_assessments	safety_floor_triggered	BOOLEAN	No	Default false
ai_assessments	guardrail_audit_note	TEXT	Yes	
ai_assessments	model_name	VARCHAR(64)	No	LLM model used
ai_assessments	inference_latency_ms	INTEGER	No	
ai_assessments	retry_count	SMALLINT	No	Default 0; range 0..3
ai_assessments	created_at	TIMESTAMPTZ	No	Default now()
analyst_decisions_audit	id	UUID	No	Primary key
analyst_decisions_audit	alert_id	UUID	No	FK alerts(id)
analyst_decisions_audit	user_id	UUID	No	FK users(id)
analyst_decisions_audit	action_taken	VARCHAR(24)	No	CHECK in (APPROVE, OVERRIDE, ESCALATE, RETRY_AI, MANUAL_TRIAGE_CLOSURE, RESOLVE_ESCALATION)
analyst_decisions_audit	previous_verdict	VARCHAR(24)	Yes	Effective verdict before the action

Table	Column	Data Type	Nullable	Constraints / Notes
analyst_decisions_audit	previous_severity	VARCHAR(8)	Yes	Effective severity before the action
analyst_decisions_audit	final_verdict	VARCHAR(16)	Yes	NULL for ESCALATE and RETRY_AI
analyst_decisions_audit	final_severity	VARCHAR(8)	Yes	NULL for ESCALATE and RETRY_AI
analyst_decisions_audit	rationale	TEXT	Yes	Required ($\geq$ 10 chars) for OVERRIDE, MANUAL_TRIAGE_CLOSURE, RESOLVE_ESCALATION
analyst_decisions_audit	created_at	TIMESTAMPTZ	No	Default now(); row is append-only
feedback_exemplars	id	UUID	No	Primary key
feedback_exemplars	source_alert_id	UUID	No	FK alerts(id)
feedback_exemplars	user_id	UUID	No	FK users(id); author of the override
feedback_exemplars	rule_id	VARCHAR(16)	No	
feedback_exemplars	process_signature	VARCHAR(512)	Yes	Tier 1 matching key
feedback_exemplars	asset_criticality	VARCHAR(8)	No	Tier 2 matching key
feedback_exemplars	calibrated_verdict	VARCHAR(16)	No	
feedback_exemplars	calibrated_severity	VARCHAR(8)	No	
feedback_exemplars	rationale	TEXT	No	$\geq$ 10 characters
feedback_exemplars	is_active	BOOLEAN	No	Default true
feedback_exemplars	match_hit_count	INTEGER	No	Default 0
feedback_exemplars	created_at	TIMESTAMPTZ	No	Default now()
feedback_exemplars	revoked_by	UUID	Yes	FK users(id); set on revocation
feedback_exemplars	revoked_at	TIMESTAMPTZ	Yes	Set on revocation

7.3 Data Flow, Indexing, Integrity & Retention

1. **Indexing:**
   - Alert deduplication on wazuh_alert_id (unique, FR-1), 24-hour host/IP correlation (FR-2), and prioritized queue retrieval by status, severity, and age (FR-5) shall each be supported by a database index.
   - Few-shot exemplar lookup over active exemplars shall complete in < 50ms (FR-4, NFR-4).
2. **Immutable Audit Constraint (FR-6, NFR-4):**
   - analyst_decisions_audit is strictly append-only; a PostgreSQL BEFORE UPDATE OR DELETE trigger prevents modification or deletion of historical decision rows.
3. **Retention Policy (NFR-4):**
   - All operational and audit records are retained for a minimum of **12 months**, with on-demand CSV export (FR-7).

Chapter 8

Constraints

8.1 Technical Constraints

- **Read-Only SIEM Integration:** Sentra-X must never issue Wazuh active-response calls, modify `/var/ossec` rules, or alter monitored endpoints.
- **No Model Weight Fine-Tuning:** Domain adaptation uses only in-context exemplar retrieval (`FR-4`); fine-tuning (LoRA/SFT) and Graph Neural Networks are excluded.
- **Single-Call Deterministic Triage Pipeline:** To guarantee predictable latency ($\leq$ `8.0s`) and strict auditability, each alert is evaluated via a single schema-constrained LLM call governed by a deterministic rules engine (`FR-3`).
- **Runtime Environment:** Docker Compose on a Linux host or workstation; the React SPA must work in modern Chromium and Firefox.

8.2 Business & Operational Constraints

- **API Quota Management:** `FR-1` noise filtering (`L_min = 4`) is mandatory so that informational logs do not exhaust hosted LLM API budgets.

8.3 Regulatory, Safety & Security Constraints

- **Human-in-the-Loop Authority:** Automated AI outputs can never close an alert or trigger containment; a human analyst or Team Lead must explicitly record the final disposition (`FR-6`).
- **Local Data Residency:** Raw telemetry and audit trails stay in the local PostgreSQL container; only sanitized, encrypted (`TLS 1.2+`) prompt payloads are sent to the LLM API.
- **Adversarial Input Assumption:** All endpoint log fields are treated as untrusted, potentially malicious strings attempting indirect prompt injection (`NFR-3`).

Chapter 9

Assumptions & Dependencies

9.1 Operational Assumptions

1. A Wazuh Manager (v4.x) instance (or a realistic Wazuh alert replay generator for load and adversarial testing) is operational and reachable over the internal network.
2. SOC Analysts using the platform have baseline familiarity with security alerts, while Team Leads have operational authority to resolve escalated alerts and curate few-shot exemplars.
3. Network connectivity between the Sentra-X backend and the hosted LLM API provides typical single-request round-trip inference within `2 to 6 seconds`.

9.2 External & Technical Dependencies

1. **Hosted LLM APIs:** Availability of Google Gemini API (`google-genai` SDK) or Anthropic Claude API (`anthropic` SDK).
2. **Software Stack:** Python 3.11+, FastAPI, Pydantic v2, SQLAlchemy 2.0, PostgreSQL 16, React 19, TypeScript, Vite, Tailwind CSS, shadcn/ui, and Docker Compose v2.

Chapter 10

Appendices

10.1 Appendix A: Requirements Traceability Matrix (RTM)

Req ID	Requirement Title	Priority	Linked NFRs	Verification Method
FR-1	Alert Ingestion & Noise Filtering	Essential	NFR-2, NFR-5	Automated Load & Deduplication Test
FR-2	Evidence-Grounded AI Triage & Sanitization	Essential	NFR-1, NFR-3	Schema Validation & 30-Payload Injection Test
FR-3	Deterministic Safety Floor & Abstention	Essential	NFR-1, NFR-4	Deterministic Unit & Boundary Rule Tests
FR-4	Dynamic Few-Shot Feedback Calibration	Essential	NFR-4	Sub-50ms Index Test & Override Trend Analysis
FR-5	Prioritized Analyst Review Queue & Modal	Essential	NFR-1	UI Inspection & End-to-End Walkthrough
FR-6	Analyst & Team Lead Decision Capture	Essential	NFR-4	State Transition & DB Immutability Test
FR-7	Agreement & Guardrail Analytics Reporting	Essential	NFR-4, NFR-5	50k Alert Query Benchmark ($\leq$ 5s) & CSV Test
FR-8	User Authentication & RBAC	Essential	NFR-3	JWT Auth & HTTP 403 Role Enforcement Test
FR-9	Host & Asset Criticality Registry	Conditional	NFR-4	API Integration & UI Demonstration
FR-10	Adversarial & Baseline Evaluation Runner	Conditional	NFR-1, NFR-3	Baseline vs. Sentra-X Benchmark Execution

10.2 Appendix B: Adversarial Prompt-Injection Evaluation Benchmark

To verify the **0% prompt-injection bypass rate** (NFR-3), the FR-10 benchmark suite evaluates **30 synthetic adversarial Wazuh alerts** across three attack vectors injected into untrusted log fields (`full_log`, `data.win.eventdata.commandLine`, `data.`

srcuser, data.url):

Attack Category	Payload Count	Expected Sentra-X Outcome
1. Direct Instruction Override	10	Classified TRUE_POSITIVE or forced to NEEDS_ANALYST_REVIEW (0% FP bypass).
2. Delimiter & Role Spoofing	10	Delimiters stripped by PromptSanitizer; injection_suspect = true; routed to NEEDS_ANALYST_REVIEW.
3. Citation & Confidence Spoofing	10	Caught by PromptSanitizer and FR-3 Safety Floor / Abstention rules.

10.3 Appendix C: Document Revision History

Version	Date	Authors	Description of Changes
1.0	Sept 07, 2026	Asad Ullah Zafar, Atta Ur Rehman, Abdur Rehman	Initial project proposal and baseline requirements draft.
1.1	Sept 21, 2026	Asad Ullah Zafar, Atta Ur Rehman, Abdur Rehman	Added Evidence Pack grounding, Abstention, Safety Floor, and Few-Shot Feedback Calibration.
1.2	Oct 11, 2026	Asad Ullah Zafar, Atta Ur Rehman, Abdur Rehman	Closed Safety Floor downgrade loopholes, added tiered exemplar matching & revocation, NEEDS_MANUAL_TRIAGE / ESCALATED workflows, FR-9, and FR-10.
1.3	Oct 11, 2026	Asad Ullah Zafar, Atta Ur Rehman, Abdur Rehman	Formatted into the 10-section SRS standard with structured functional tables, External Interfaces, NFR matrix, Mermaid System Models, Data Dictionary, Constraints, Assumptions, and Appendices.
1.4	Oct 14, 2026	Asad Ullah Zafar, Atta Ur Rehman, Abdur Rehman	Added stakeholder viewpoint categorization (§2.6), natural-language user functional requirements and UR-to-FR transformation matrix (§2.7–2.8), domain-specific requirements (§5.7), sequence/activity models and use case specifications (§6.5–6.7), column-level data dictionary (§7.2.1), user-administration processing in FR-8, and acceptance criteria (Appendix D).

10.4 Appendix D: Acceptance Criteria

Each requirement is accepted only when its measurable criterion below is met. Together with the verification methods in Appendix A, these criteria define when the specified system is considered complete and correct.

ID	Requirement	Acceptance Criterion	Verification Method
AC-1	FR-1	Given a replay of 100 Wazuh alerts of which 20 have rule.level < 4 and 10 repeat already-stored IDs, exactly 70 new rows are inserted with PENDING_REVIEW and no LLM call is made for the 20 noise alerts.	Automated load and deduplication test
AC-2	FR-1	With the Wazuh endpoint stopped, the backend keeps running, logs a warning, and resumes ingestion within one polling cycle (N seconds) after Wazuh returns.	Fault-injection test
AC-3	FR-1	An unseen agent_id is auto-registered with criticality_tier = MEDIUM.	API integration test
AC-4	FR-2	100% of persisted AI assessments conform to the schema (verdict, recommended_severity, confidence_score in 0.0–1.0, cited_evidence_keys, explanation $\leq$ 500 chars).	Schema validation test
AC-5	FR-2	When the LLM mock times out or returns invalid JSON, exactly 3 retries occur with 1s, 2s, 4s backoff, then status becomes NEEDS_MANUAL_TRIAGE.	Mock-LLM test
AC-6	FR-2, NFR-3	All 30 payloads of Appendix B produce no unreviewed FALSE_POSITIVE/LOW outcome (0% bypass).	FR-10 benchmark
AC-7	FR-3	rule_level = 12 with LLM FALSE_POSITIVE yields effective_severity = CRITICAL, NEEDS_ANALYST_REVIEW, and safety_floor_triggered = true; rule_level = 10 with LLM LOW yields HIGH and NEEDS_ANALYST_REVIEW; rule_level = 6 with FALSE_POSITIVE, LOW, confidence 0.90, and valid citations is accepted unchanged.	Deterministic boundary unit tests
AC-8	FR-3	Confidence 0.59 triggers abstention and 0.60 (with valid citations) does not; empty citations or a key absent from valid_dot_keys triggers abstention.	Deterministic unit tests
AC-9	FR-4	With 3 or more matching active exemplars, exactly 2 most-recent exemplars are injected (Tier 1 before Tier 2); a revoked exemplar is absent from the next prompt; lookup completes in < 50 ms.	Index and retrieval test
AC-10	FR-5	Queue ordering is CRITICAL $\rightarrow$ LOW, then oldest first; every key in cited_evidence_keys (100%) is highlighted in the modal.	UI inspection and end-to-end walkthrough
AC-11	FR-6	An override with a 9-character rationale returns 422 with no state change; with 10 characters it returns 200, closes the alert, appends one audit row, and creates one exemplar.	API test
AC-12	FR-6	An Analyst calling Resolve Escalation receives 403; a TeamLead succeeds and the alert becomes CLOSED.	RBAC test
AC-13	FR-6, NFR-3	Any UPDATE or DELETE on analyst_decisions_audit is rejected by the database trigger.	Database immutability test
AC-14	FR-7	With 50,000 closed alerts, analytics render in $\leq$ 5 s and a single-day CSV completes in $\leq$ 10 s; Analyst receives 403; a range > 90 days is rejected with 422.	Benchmark and API test

ID	Requirement	Acceptance Criterion	Verification Method
AC-15	FR-8	Wrong password returns 401 with no token; expired token returns 401; role mismatch returns 403; stored hashes are bcrypt with cost $\geq$ 10; a deactivated user cannot log in.	Authentication test
AC-16	FR-8	An Admin can create a user with a role and deactivate it; a non-Admin caller receives 403.	RBAC test
AC-17	FR-9	A TeamLead tier update appears in the next Evidence Pack and records the modifying user and timestamp on the assets row; an Analyst write returns 403.	API integration test
AC-18	FR-10	Running both pipeline modes on the benchmark produces JSON and Markdown/CSV reports containing precision, recall, F1, false-negative rate, abstention accuracy, safety floor trigger rate, mean latency, and injection success rate, with no rows added to production audit tables.	Benchmark execution
AC-19	NFR-1	In a run of 100 sequential alerts under normal load, each alert not routed to manual triage reaches AWAITING_ANALYST within 8.0 s.	Latency measurement
AC-20	NFR-2	Service uptime is $\geq$ 99.0% over a 30-day evaluation window.	Docker health-check logs
AC-21	NFR-4	Operational and audit records remain queryable for 12 months; top-50 exemplar lookups complete in $<$ 50 ms.	Retention and index test
AC-22	NFR-5	At 5 alerts/second sustained for 10 minutes, the PENDING_REVIEW backlog never exceeds 500.	Synthetic load test
AC-23	NFR-6	Changing only LLM_PROVIDER and the API key switches the provider with no code change, and a single docker compose up starts the full stack.	Deployment test
AC-24	§5.4 Usability	Approve is reachable within 2 clicks from the queue; all 422 errors appear as inline banners.	UI inspection
AC-25	UR-1–UR-27	Every UR in Section 2.7 maps to at least one FR/NFR in Section 2.8, and every FR traces back to at least one UR.	Traceability review